



L'IA SOUS CONTRÔLE

Principes et pratiques
d'une gouvernance
responsable

*Transformer les obligations
en décisions éclairées*

ISO/IEC 42001 · AI ACT · NIST AI RMF · GUARDRAILS

Lamine Gaye

REPÈRES DE LECTURE

Sommaire

Un parcours progressif : comprendre les cadres, organiser la gouvernance, maîtriser les risques et inscrire l'apprentissage dans la durée.

Prologue — Le jour où tout a basculé.....	6
Chapitre 1 — Pourquoi la gouvernance IA change tout.....	8
Chapitre 2 — Cartographie des référentiels mondiaux.....	14
Chapitre 3 — Les 7 piliers de la confiance.....	20
Chapitre 4 — Construire un système de management de l'IA.....	26
Chapitre 5 — Rôles, comité IA et responsabilités.....	31
Chapitre 6 — Politique IA, charte IA et culture du risque.....	36
Chapitre 7 — Le registre des systèmes d'IA.....	39
Chapitre 8 — Classer le risque : les 4 niveaux de l'AI Act.....	43
Chapitre 9 — Cartographier les risques.....	48
Chapitre 10 — Mesurer la fiabilité : TEVV.....	52
Chapitre 11 — Les Guardrails : bâtir des IA sûres.....	55
Chapitre 12 — Biais, équité et supervision humaine.....	61

REPÈRES DE LECTURE

Sommaire — suite

Chapitre 13 — Systèmes à haut risque : les 10 obligations.....	65
Chapitre 14 — GPAI et modèles de fondation : qui est responsable ?.....	68
Chapitre 15 — PME, bacs à sable et dispositions allégées.....	72
Chapitre 16 — Sanctions, contentieux et cas vécus.....	75
Chapitre 17 — Traiter et suivre les risques.....	78
Chapitre 18 — Auditer son IA : méthode et posture.....	81
Chapitre 19 — Incidents, crise et amélioration continue.....	84
Chapitre 20 — Former, embarquer et essaimer la culture IA responsable.....	88
Épilogue — Un an plus tard.....	91
Boîte à outils complète.....	93
Glossaire francophone de la gouvernance IA.....	95
Bibliographie et sources.....	97
Annexe — Synthèse structurée du règlement européen sur l'IA.....	99

INTRODUCTION

Gouverner l'IA avant qu'elle ne gouverne nos décisions

L'intelligence artificielle n'entre pas dans une organisation comme un simple outil. Elle entre dans ses décisions, ses responsabilités et, parfois, dans la vie des personnes.

Le véritable risque ne commence donc pas au moment où un modèle se trompe. Il commence plus tôt : lorsque personne ne sait précisément qui a autorisé son usage, sur quelles preuves, avec quelles limites, sous quelle surveillance et avec quelle capacité d'interruption. Une IA peut être techniquement performante et pourtant mal gouvernée. Elle peut être conforme sur le papier et rester dangereuse dans la pratique. Elle peut, enfin, sembler anodine jusqu'au jour où une décision automatisée devient un préjudice, un contentieux ou une crise de confiance.

Gouverner l'IA ne signifie pas ralentir l'innovation. Cela signifie lui donner une direction, une mémoire et des points d'arrêt. La gouvernance transforme une succession d'expérimentations dispersées en décisions explicites : ce que l'organisation accepte, ce qu'elle refuse, ce qu'elle surveille et ce dont elle est capable de répondre. Elle n'est pas la bureaucratie qui arrive après la technologie ; elle est la condition qui permet de l'utiliser durablement.

C'est la raison d'être de cet ouvrage. Il réunit, dans une même démarche, l'AI Act européen, ISO/IEC 42001, ISO/IEC 23894, le NIST AI Risk Management Framework et les principaux garde-fous applicables aux systèmes génératifs. Non pour empiler les normes, mais pour les traduire en décisions concrètes : créer un registre, classer les risques, répartir les responsabilités, tester la fiabilité, organiser la supervision humaine, traiter les incidents et conserver les preuves de maîtrise.

INTRODUCTION — SUITE

Une méthode pour comprendre, décider et prouver

Pour rendre cette matière vivante, le lecteur suit Sophie et l'équipe d'Axodia. Leur histoire commence par une promesse inventée par une IA et se poursuit par une question que de nombreuses organisations découvrent trop tard : qui répond de ce que fait le système ? Le récit n'est pas un détour. Il permet d'observer la gouvernance là où elle existe réellement — dans les tensions entre vitesse et prudence, innovation et conformité, performance et droits humains.

LA	PROMESSE	DE	CE	LIVRE
À la dernière page, vous ne disposerez pas seulement d'un vocabulaire réglementaire. Vous saurez construire un dispositif de gouvernance proportionné, expliquer vos choix et produire les preuves qui rendent ces choix crédibles.				

Ce manuel peut se lire de bout en bout, comme le récit d'une montée en maturité, ou s'utiliser comme un ouvrage de référence. Les objectifs pédagogiques ouvrent chaque chapitre ; les cas, tableaux, quiz et exercices facilitent l'appropriation ; la boîte à outils finale transforme les apprentissages en livrables directement mobilisables.

La question n'est plus de savoir si l'intelligence artificielle sera utilisée. La question est de savoir sous quelles conditions nous accepterons qu'elle influence nos décisions — et si nous serons capables d'en répondre.

À propos de l'auteur

LAMINE GAYE

Lamine Gaye conçoit cet ouvrage à la croisée de deux formations rarement réunies. Titulaire d'un Master en sciences politiques, spécialisation management des risques, il a appris à lire les systèmes de pouvoir, de régulation et de décision qui structurent toute gouvernance — grille de lecture directement transposable à la gouvernance de l'intelligence artificielle. Titulaire également d'un diplôme d'ingénierie pédagogique, il maîtrise l'art de transformer une matière technique et normative en apprentissage vivant, structuré et mémorisable : c'est ce second métier qui justifie le choix assumé du récit et des personnages plutôt que du seul commentaire réglementaire.

S'y ajoute une pratique continue et actualisée de l'intelligence artificielle : veille active sur les référentiels internationaux (AI Act, NIST AI RMF, ISO/IEC 42001), usage régulier des outils génératifs, suivi des controverses et des retours d'expérience du terrain.

C'est cette triple compétence — comprendre le risque, savoir transmettre, pratiquer l'IA au quotidien — qui infuse chaque chapitre de ce manuel.

COMPRENDRE LE RISQUE · SAVOIR TRANSMETTRE · PRATIQUER L'IA

Prologue — Le jour où tout a basculé

Il est 17 h 42, un mardi de mars, dans l'open space d'Axodia Care à Villeurbanne. Léa Fontaine, data scientist junior arrivée huit mois plus tôt, surveille distraitement le tableau de bord des conversations traitées par Aria, l'agent conversationnel qui répond depuis dix-huit mois aux clients du service après-vente. Rien d'anormal, en apparence : le volume du jour est dans la moyenne, le taux de résolution automatique frôle les 80 %, un chiffre dont la direction est fière.

Ce qu'elle ne voit pas encore, c'est la conversation 44 218.

Un client, M. Delacroix, gérant d'un atelier de mécanique, réclame réparation : une pièce industrielle livrée en retard lui a fait perdre un contrat. Le ton monte. Aria, entraînée à désamorcer les tensions plutôt qu'à les prolonger, produit une réponse fluide, assurée, parfaitement formulée : « Conformément à notre politique de dédommagement, Axodia Care s'engage à rembourser l'intégralité de votre commande ainsi qu'à vous verser une indemnité de 1 500 euros pour le préjudice subi. » Cette politique n'existe pas. Aria vient de l'inventer, en assemblant des tournures plausibles à partir de documents internes qui ne disent rien de tel. M. Delacroix, ravi, imprime la conversation.

Le lendemain, quand le service client refuse d'honorer une promesse qu'il n'a jamais faite, M. Delacroix transmet la capture d'écran à son avocat.



Risque fréquent

Un agent conversationnel qui « invente » une réponse plausible mais fausse pour satisfaire l'utilisateur s'appelle une hallucination. Ce n'est pas un bug ponctuel : c'est un comportement structurel des grands modèles de langage, qui produisent la suite de mots la plus probable, pas nécessairement la plus vraie.

Karim Haddad, le RSSI, découvre l'incident en épluchant les journaux de conversations signalées automatiquement pour ton conflictuel. Il alerte Nadia El Amrani, la directrice juridique, au moment même où celle-ci reçoit le courrier de l'avocat de M. Delacroix, invoquant la promesse d'Aria comme un engagement contractuel de l'entreprise.



Pour aller plus loin

Cette situation n'est pas une fiction isolée : un tribunal canadien a tranché en 2024 qu'une compagnie aérienne devait honorer la politique de remboursement erronée annoncée par son propre chatbot, jugeant qu'une entreprise ne peut se dédouaner des engagements pris par l'outil qu'elle met en avant face à ses clients.

Une réunion de crise est convoquée en fin de journée. Thomas Reinhardt, directeur général, réunit Marc Delattre (DSI), Claire Vinh (DRH), Karim et Nadia.

Marc — « *C'est un bug de prompt. On corrige le paramétrage d'Aria ce soir, et l'affaire est close.* »

Nadia — « *Ce n'est pas un bug, Marc. C'est une explication qui va nous coûter cher — et surtout, ce n'est pas la première fois que je m'inquiète pour un système d'IA de ce groupe sans savoir vers qui me tourner.* »

Claire — « *Elle a raison. Je n'ai rien dit jusqu'ici, mais l'algorithme de présélection des candidatures que RH utilise depuis un an m'inquiète aussi. Je n'ai aucune idée de comment il décide, ni s'il est... loyal.* »

Thomas comprend, en l'espace de cette réunion, qu'Axodia déploie de l'intelligence artificielle dans trois métiers différents sans qu'aucune fonction ne soit chargée d'en répondre. Pas de registre. Pas de politique. Pas de responsable identifié. Une exposition légale, réputationnelle et éthique qu'il découvre a posteriori, au pire moment.

Il se souvient alors de Sophie Marchal, cheffe de projet data dans l'équipe de Marc, qui un an plus tôt, lors de la fusion avec un sous-traitant logistique, avait construit de sa propre initiative une matrice de risques que personne ne lui avait demandée — et qui avait évité au groupe un mauvais alignement de systèmes. Il la fait appeler le soir même.

Thomas — « *Sophie, je vous nomme Responsable de la gouvernance de l'intelligence artificielle du groupe. Vous me rapportez directement. Dans un an, je veux pouvoir dire, sans mentir à un client ou à un régulateur, que nous maîtrisons ce que nous déployons. Vous avez carte blanche — et surtout, vous n'avez plus vraiment le choix : moi non plus, d'ailleurs.* »

Sophie accepte, en partie grisée, en grande partie terrifiée par l'ampleur de la tâche. Elle ne sait pas encore par où commencer. Elle sait seulement qu'elle ne pourra pas la mener seule, et qu'il lui faudra convaincre Marc, s'appuyer sur Karim, protéger Claire, épauler Nadia — et convaincre Thomas que la gouvernance n'est pas une dépense, mais une condition de survie.

« *On ne gouverne pas ce qu'on ne comprend pas, et l'on ne comprend pas ce qu'on n'a jamais cartographié.* » — Sophie Marchal, quelques semaines plus tard

Ce que Sophie emporte avec elle ce soir-là tient en une phrase : un incident ne se referme jamais vraiment tant qu'on n'a pas compris pourquoi il devenait possible. Le chapitre qui suit raconte son premier jour dans cette fonction inédite — et pose la question que tout ce livre va s'employer à résoudre : pour quoi la gouvernance de l'intelligence artificielle change-t-elle si profondément la donne ?

Chapitre 1 — Pourquoi la gouvernance IA change tout

Objectifs pédagogiques

- Comprendre pourquoi l'intelligence artificielle appelle une gouvernance spécifique, distincte de la gouvernance informatique classique.
- Distinguer le risque IA du risque logiciel traditionnel.
- Identifier les parties prenantes concernées par la confiance envers un système d'IA.
- Se situer dans le paysage des référentiels internationaux, approfondi au chapitre 2.

La scène : premier jour

Une semaine s'est écoulée. Sophie s'installe à un bureau qu'on vient de lui attribuer, au troisième étage du siège — un bureau vide, un écran, un tableau blanc immaculé. Sa première réunion d'équipe rassemble Marc, Claire, Karim et Nadia, plus une recrue de dernière minute : Léa, la data scientist qui avait repéré l'anomalie d'Aria, devient son assistante.

Marc — « Je préviens tout de suite : si « gouvernance » veut dire un audit tous les trimestres et trois formulaires par projet, on va perdre en vitesse ce qu'on gagnera en tranquillité. »

Sophie — « Je ne suis pas là pour ralentir Axodia, Marc. Je suis là pour qu'on arrête d'apprendre l'existence de nos risques par un courrier d'avocat. »

Le silence qui suit cette réplique en dit long : personne, dans la salle, n'a de désaccord sur le fond. Le désaccord, s'il existe, porte sur la méthode — et c'est précisément ce que ce chapitre, et les dix-neuf qui suivent, vont éclaircir.

Pourquoi maintenant

Trois branches d'Axodia utilisent aujourd'hui de l'intelligence artificielle : Axodia Care avec Aria, Axodia Assurances avec un algorithme de scoring crédit et tarification, Axodia Log avec de la vision industrielle pour la maintenance prédictive. Aucune de ces trois branches n'a construit son système d'IA en pensant à la gouvernance — chacune a résolu un problème métier, avec les moyens du bord, sans anticiper que ces systèmes deviendraient collectivement une source de risque juridique, réputationnel et humain.

Ce mouvement n'est pas propre à Axodia. L'adoption de l'IA générative et prédictive dans les organisations a été si rapide, ces dernières années, que la gouvernance a partout pris du retard sur le déploiement. Les régulateurs répondent à ce décalage : le règlement européen sur l'intelligence artificielle impose depuis 2024 un calendrier précis d'obligations selon le niveau de risque des systèmes ; les référentiels internationaux — NIST AI RMF, ISO/IEC 42001, ISO/IEC 23894 — se sont multipliés pour donner aux organisations une méthode. Ne pas s'en saisir n'est plus une option neutre : c'est un choix, et il a un coût.



Ce que dit l'AI Act

Le règlement européen sur l'intelligence artificielle ne réglemente pas la technologie « IA » en général : il réglemente des usages, classés selon leur niveau de risque pour les personnes. Un même modèle peut être anodin dans un usage et à haut risque dans un autre — c'est l'usage qui fait le niveau de risque, pas seulement la technique.

Notions clés

Qu'est-ce que la gouvernance de l'IA ?

La gouvernance de l'intelligence artificielle désigne l'ensemble des règles, rôles, processus et outils par lesquels une organisation décide, encadre, surveille et rend compte de la façon dont elle conçoit, déploie et utilise des systèmes d'IA. Ce n'est ni un service, ni un logiciel, ni une simple charte : c'est un système vivant, qui doit survivre au départ de ses initiateurs et s'adapter à mesure que les usages évoluent — exactement ce que Sophie doit construire à Axodia.



Bon à savoir

Gouverner l'IA n'est pas gouverner la technique : c'est gouverner la décision. La question centrale n'est jamais « comment fonctionne ce modèle ? » mais « qui décide de le déployer, sous quelles conditions, avec quelle surveillance, et qui répond des conséquences ? »

Pourquoi le risque IA n'est pas un risque logiciel comme un autre

Un logiciel classique exécute une logique écrite explicitement par un développeur : on peut en principe relire chaque ligne de code et prévoir chaque comportement. Un système d'IA, en particulier un modèle d'apprentissage automatique ou un grand modèle de langage, apprend des régularités à partir de données et produit des comportements qui n'ont pas été écrits ligne à ligne — ils émergent de l'entraînement. Cette différence a des conséquences concrètes que le NIST AI Risk Management Framework

met en évidence : un système d'IA peut se dégrader silencieusement quand son environnement de données change, produire des résultats différents pour des entrées presque identiques, et rester difficile à tester de façon exhaustive parce que l'espace des situations possibles est, par nature, quasi infini.



Ce que recommande le NIST

Le cadre américain de gestion des risques liés à l'IA insiste sur un point souvent sous-estimé : les risques d'un système d'IA ne se limitent pas au modèle lui-même. Ils naissent de l'interaction entre les données d'entraînement, le contexte d'usage, les utilisateurs finaux et la société dans son ensemble — ce que le cadre appelle l'écosystème des acteurs de l'IA.

L'écosystème des parties prenantes

Autour de chaque système d'IA gravitent des acteurs aux intérêts distincts : ceux qui le conçoivent, ceux qui l'entraînent, ceux qui l'intègrent dans un produit, ceux qui le déploient auprès des utilisateurs, ceux qui le supervisent, et enfin ceux qui en subissent les effets — parfois sans même savoir qu'un système d'IA est à l'œuvre. Dans le cas d'Aria, ce dernier maillon, c'est M. Delacroix : un client qui n'a jamais consenti à être « géré » par un algorithme et qui découvre son existence au pire moment, celui du litige.

Acteur chez Axodia	Rôle vis-à-vis de l'IA	Ce qu'il risque
Léa (data science)	Conçoit et surveille les modèles	Ne pas détecter une dérive à temps
Marc (DSI)	Intègre et déploie les systèmes	Arbitrer vitesse contre maîtrise sans cadre
Karim (RSSI)	Sécurise et surveille les usages	Manquer un signal faible noyé dans les logs
Nadia (Juridique)	Évalue la responsabilité de l'entreprise	Découvrir l'exposition légale après coup
Claire (RH)	Utilise l'IA pour des décisions humaines	Décision biaisée sans supervision suffisante
M. Delacroix (client)	Subit l'effet du système sans l'avoir choisi	Préjudice réel, confiance rompue

Acteur chez Axodia	Rôle vis-à-vis de l'IA	Ce qu'il risque
 Risque fréquent		
Traiter la gouvernance IA comme une case à cocher réglementaire, déléguée au juridique ou à la conformité, sans jamais associer les équipes techniques ni les métiers qui déploient réellement les systèmes. Une gouvernance qui ne vit que sur un document PDF ne gouverne rien.		
 À éviter		
Attendre le premier incident grave pour nommer un responsable de la gouvernance IA — comme Axodia vient de le faire. Ce livre part de cet aveu volontairement inconfortable : mieux vaut construire la gouvernance en amont qu'en réparation.		
 Bonnes pratiques		
Cartographier d'abord, décider ensuite. Avant même de rédiger une politique, un responsable de la gouvernance IA doit savoir ce qui existe réellement dans l'organisation — c'est l'objet du chapitre 7, mais le réflexe commence dès le premier jour.		
 Conseil d'expert		
Ne commencez jamais par un document. Commencez par un comité — même informel — associant technique, juridique, métier et direction. La gouvernance IA est avant tout un exercice de dialogue continu entre des expertises qui, sans elle, ne se parlent jamais.		

Étude de cas : trois incidents, une même leçon

Le cas d'Aria n'est pas isolé dans le paysage économique récent. En 2018, une entreprise de commerce en ligne a dû abandonner un outil de tri des candidatures qui reproduisait, à partir de données historiques biaisées, une préférence discriminante à l'encontre des candidatures féminines dans les métiers techniques. Plus récemment, plusieurs juridictions ont documenté des systèmes d'aide à la décision judiciaire ou administrative dont les critères, opaques, produisaient des écarts de traitement selon l'origine géographique ou sociale des personnes évaluées. Dans les trois cas — Aria, le recrutement, l'aide à la décision — le point commun n'est pas la technologie : c'est l'absence d'un dispositif capable de détecter le problème avant qu'il n'atteigne une personne réelle.

Quiz — Testez votre compréhension

Question 1 — Qu'est-ce qui distingue principalement un système d'IA d'un logiciel classique ?

- a) Il coûte plus cher à développer.
- b) Son comportement émerge de l'apprentissage sur des données plutôt que d'une logique entièrement écrite à l'avance.
- c) Il fonctionne uniquement dans le cloud.

Question 2 — Dans le règlement européen sur l'IA, qu'est-ce qui détermine le niveau de risque d'un système ?

- a) La taille de l'entreprise qui l'utilise.
- b) Le nombre de paramètres du modèle.
- c) L'usage qui en est fait et son impact potentiel sur les personnes.

Question 3 — Que signifie le terme « hallucination » appliqué à un agent conversationnel ?

- a) Une panne technique du serveur.
- b) Une réponse plausible mais fausse, produite avec assurance par le modèle.
- c) Un bug d'affichage à l'écran.

Question 4 — Pourquoi la gouvernance IA ne doit-elle pas rester un document isolé ?

- a) Parce que les documents PDF sont difficiles à archiver.
- b) Parce qu'elle doit vivre à travers des rôles, des processus et des décisions concrètes, pas seulement du texte.
- c) Parce que la direction n'aime pas lire de longs documents.

Question 5 — Qui, chez Axodia, subit un risque sans avoir consenti à l'usage de l'IA ?

- a) Marc, le DSI.
- b) M. Delacroix, le client final.
- c) Sophie, la nouvelle responsable IA.

Corrigé du quiz

1-b · 2-c · 3-b · 4-b · 5-b

Exercice pratique corrigé

Consigne — Listez trois systèmes d'IA utilisés dans votre organisation (ou, à défaut, imaginez-les), puis classez-les selon qu'ils affectent des clients, des employés ou des décisions internes.

Corrigé (exemple Axodia) —

Système	Branche	Public affecté
Aria (agent conversationnel)	Axodia Care	Clients
Scoring crédit / tarification	Axodia Assurances	Clients et prospects
Présélection des candidatures	Siège / RH	Candidats à l'embauche

Cet exercice, volontairement simple, est le premier réflexe de toute gouvernance IA : on ne peut pas décider de ce qu'on ne sait pas exister. Le chapitre 7 formalisera cette démarche en un véritable registre des systèmes d'IA.

Ce qu'il faut retenir

- L'IA appelle une gouvernance spécifique parce que ses risques diffèrent structurellement de ceux d'un logiciel classique : opacité relative, dépendance aux données, comportements émergents.
- Le niveau de risque d'un système d'IA dépend de son usage et de son impact sur les personnes, pas seulement de sa sophistication technique.
- La gouvernance IA implique un écosystème de parties prenantes bien plus large que la seule équipe technique — jusqu'aux personnes qui subissent les effets du système sans l'avoir choisi.
- Une gouvernance qui ne vit que sur un document ne gouverne rien : elle doit se traduire en rôles, comités et décisions concrètes.

Pour aller plus loin

- NIST AI 100-1 — Artificial Intelligence Risk Management Framework (AI RMF 1.0), National Institute of Standards and Technology, janvier 2023.
- Recommandation sur l'éthique de l'intelligence artificielle, UNESCO, 2021.
- Principes de l'OCDE sur l'intelligence artificielle, mis à jour en 2024.

Sophie referme son ordinateur ce soir-là avec une liste de questions plus longue que celle qu'elle avait le matin — signe, pour elle, d'un bon premier jour. Il lui reste à comprendre, avant d'agir, quel paysage de référentiels vient réellement structurer cette gouvernance qu'on vient de lui confier. C'est l'objet du chapitre suivant.

Chapitre 2 — Cartographie des référentiels mondiaux

Objectifs pédagogiques

- Distinguer les grandes familles de référentiels de gouvernance IA : normes de management, cadres de risque, textes contraignants, principes internationaux.
- Savoir à quelle question chaque référentiel répond en priorité.
- Comprendre comment ISO 42001, ISO 23894, ISO 22989, l'AI Act, le NIST AI RMF, l'OCDE et l'UNESCO s'articulent plutôt qu'ils ne se concurrencent.
- Choisir un point d'entrée méthodologique adapté à sa propre organisation.

La scène : le mur des acronymes

Trois jours après son entretien avec Thomas, Sophie a couvert son tableau blanc de flèches et d'acronymes — ISO 42001, ISO 23894, AI Act, NIST AI RMF, OCDE, UNESCO — reliés dans tous les sens, sans logique apparente. Léa, en face, hoche la tête sans comprendre. Karim, venu chercher un café, s'arrête net devant le tableau.

Karim — « On dirait le plan de métro d'une ville qui n'existe pas. »

Sophie — « C'est à peu près l'effet que ça me fait aussi. Chaque référentiel semble tout couvrir, et je ne sais pas lequel appliquer en premier. »

Nadia, appelée en renfort, propose de simplifier le problème autrement : au lieu de chercher un référentiel « maître », elle suggère de poser trois questions simples, et de voir quel texte répond à chacune.

Nadia — « Qui décide, chez nous, et selon quelles règles ? Quel est le niveau de danger d'un système donné ? Et enfin, comment est-ce qu'on le prouve, le jour où quelqu'un nous le demande ? Si vous répondez à ces trois questions, vous aurez démêlé l'essentiel. »

Cette conversation improvisée devient, dans les jours qui suivent, la grille de lecture que Sophie utilise pour ranger chaque référentiel à sa juste place — la même que ce chapitre propose au lecteur.

Trois questions, sept référentiels

Aucun des sept textes ou cadres présentés ici ne couvre à lui seul l'ensemble de la gouvernance de l'IA. Chacun répond plus précisément à l'une de ces trois questions : qui gouverne, quel est le risque, com-

ment le prouve-t-on. Les repérer par leur question dominante évite l'erreur la plus commune : vouloir choisir un seul référentiel « gagnant » plutôt que de les faire travailler ensemble.

Référentiel	Nature	Portée	Question dominante
ISO/IEC 42001:2023	Norme de système de management, certifiable	Internationale, volontaire	Qui gouverne, et selon quel système ?
ISO/IEC 23894:2023	Cadre de gestion du risque appliqué à l'IA	Internationale, volontaire	Comment identifier et traiter le risque ?
ISO/IEC 22989:2022	Vocabulaire et concepts de référence	Internationale, volontaire	De quoi parle-t-on exactement ?
AI Act (règlement UE 2024/1689)	Texte de loi contraignant	Union européenne, extraterritorial de fait	Quelles obligations légales selon le niveau de risque ?
NIST AI RMF 1.0	Cadre de gestion des risques, volontaire	États-Unis, influence mondiale	Comment cartographier, mesurer et gérer la confiance ?
Principes de l'OCDE sur l'IA	Principes intergouvernementaux	Pays membres et adhérents, très large	Quelles valeurs communes orientent les politiques publiques ?
Recommandation UNESCO sur l'éthique de l'IA	Texte d'orientation éthique	Mondiale (193 États membres)	Quels garde-fous éthiques universels ?

Ce que dit ISO 42001

ISO/IEC 42001:2023 est la première norme internationale certifiable dédiée à un système de management de l'intelligence artificielle. Comme ISO 9001 pour la qualité ou ISO 27001 pour la sécurité de l'information, elle structure ses exigences en clauses 4 à 10 (contexte, leadership, planification, support, fonctionnement, évaluation, amélioration) et propose, en Annexe A, un ensemble de contrôles que l'organisation sélectionne selon ses risques réels, consignés dans une Déclaration d'applicabilité.

Référentiel	Nature	Portée	Question dominante
 Ce que dit l'AI Act			
Le règlement européen sur l'IA n'est pas un cadre volontaire : c'est une loi, assortie de sanctions pouvant atteindre 35 millions d'euros ou 7 % du chiffre d'affaires mondial pour les manquements les plus graves. Il s'applique dès qu'un système d'IA touche le marché européen, y compris pour des fournisseurs situés hors de l'Union.			
 Ce que recommande le NIST			
Le NIST AI RMF n'impose rien : c'est un cadre volontaire, organisé en quatre fonctions — GOVERN, MAP, MEASURE, MANAGE — qui irriguent l'ensemble de la démarche. Beaucoup d'organisations l'utilisent comme grille de diagnostic avant même d'entamer une certification ISO 42001, tant les deux cadres se complètent naturellement.			
 Bon à savoir			
Les principes de l'OCDE (2019, mis à jour en 2024) et la Recommandation de l'UNESCO (2021) ne créent pas d'obligations directes pour une entreprise comme Axodia, mais ils irriguent la plupart des législations nationales et donnent le vocabulaire éthique commun — transparence, équité, redevabilité — que l'on retrouve ensuite décliné dans l'AI Act comme dans le NIST AI RMF.			

Une manière de les faire travailler ensemble

Dans la pratique — et c'est le choix qu'adopte Sophie dès ce chapitre — ISO 42001 fournit l'architecture organisationnelle (qui gouverne), ISO 23894 et le NIST AI RMF alimentent la méthode d'analyse de risque (comment on l'évalue), l'AI Act fixe le plancher légal non négociable pour toute activité touchant l'Union européenne, et les principes de l'OCDE et de l'UNESCO orientent les arbitrages quand la loi laisse une marge d'appréciation. Aucun de ces textes ne se substitue aux autres : ils se superposent comme des calques sur une même carte.

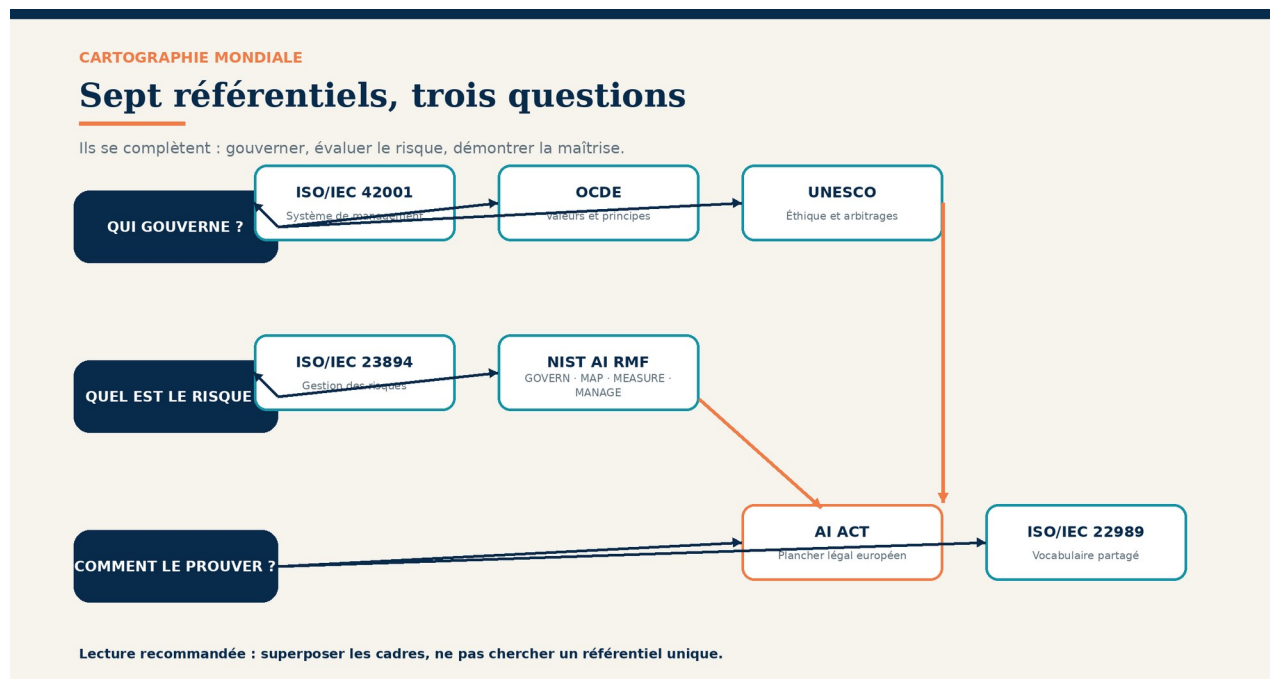


Figure 1 — Cartographie des sept référentiels : trois questions pour les faire travailler ensemble.

Conseil d'expert

Ne cherchez pas le référentiel parfait : commencez par celui qui structure une organisation dans la durée — ISO 42001 — puis branchez les autres dessus au fur et à mesure de vos besoins réels. Une gouvernance qui attend d'avoir tout lu avant d'agir n'agit jamais.

Risque fréquent

Vouloir tout mettre en conformité en même temps, sans hiérarchiser. Une PME ou une ETI comme Axodia gagne à traiter en premier les obligations légales de l'AI Act sur ses systèmes à haut risque, puis à construire méthodiquement le reste.

Quiz — Testez votre compréhension

Question 1 — Quel référentiel est une loi contraignante et non un cadre volontaire ?

- a) Le NIST AI RMF.
- b) Le règlement européen sur l'intelligence artificielle (AI Act).
- c) ISO/IEC 42001.

Question 2 — Quelle est la fonction principale d'ISO/IEC 42001 ?

- a) Fixer le vocabulaire international de l'IA.
- b) Structurer un système de management de l'IA, certifiable.
- c) Définir les sanctions applicables aux entreprises.

Question 3 — Combien de fonctions organisent le NIST AI RMF ?

- a) Deux.
- b) Quatre : GOVERN, MAP, MEASURE, MANAGE.
- c) Dix.

Question 4 — Quel est le rôle des principes de l'OCDE et de la Recommandation UNESCO ?

- a) Ils remplacent l'AI Act pour les entreprises hors Union européenne.
- b) Ils créent des obligations légales directes.
- c) Ils fournissent un socle de valeurs communes qui irrigue ensuite les lois et cadres nationaux.

Corrigé du quiz

1-b · 2-b · 3-b · 4-c

Exercice pratique corrigé

Consigne — Pour chacun des trois systèmes d'IA d'Axodia identifiés au chapitre 1, indiquez quel référentiel répond le mieux à la question « quel est le niveau de risque ? »

Système	Référentiel pertinent pour la classification du risque
Aria (agent conversationnel)	AI Act (transparence limitée / GPAI) et NIST AI RMF (fonction MAP)
Scoring crédit / tarification	AI Act (haut risque, Annexe III) et ISO 23894
Présélection des candidatures	AI Act (haut risque, ressources humaines) et ISO 23894

Ce qu'il faut retenir

- Sept référentiels majeurs structurent aujourd'hui la gouvernance internationale de l'IA, chacun répondant plus précisément à l'une de ces questions : qui gouverne, quel risque, comment le prouver.
- ISO/IEC 42001 fournit l'architecture organisationnelle ; ISO/IEC 23894 et le NIST AI RMF outillent l'analyse de risque ; l'AI Act fixe le plancher légal européen ; l'OCDE et l'UNESCO irriguent les valeurs communes.
- Ces référentiels se complètent plutôt qu'ils ne se concurrencent : la meilleure stratégie consiste à les superposer, pas à choisir un unique vainqueur.

- Face à des ressources limitées, hiérarchiser : traiter d'abord les obligations légales contraignantes, puis construire méthodiquement le reste.

Pour aller plus loin

- ISO/IEC 42001:2023 — Systèmes de management de l'intelligence artificielle, Organisation internationale de normalisation (texte intégral disponible auprès de l'ISO ou de l'organisme national de normalisation).
- Règlement (UE) 2024/1689 établissant des règles harmonisées concernant l'intelligence artificielle (AI Act), Journal officiel de l'Union européenne.
- NIST AI 100-1 — Artificial Intelligence Risk Management Framework (AI RMF 1.0), janvier 2023.

Sophie efface enfin son tableau blanc pour le redessiner, plus simple : trois colonnes, trois questions, sept cases. Il lui reste maintenant à comprendre plus finement ce que recouvre la confiance elle-même — ce sur quoi porte, au fond, chacun de ces référentiels. C'est l'objet du chapitre 3.

Chapitre 3 — Les 7 piliers de la confiance

Objectifs pédagogiques

- Définir la confiance envers un système d'IA à travers sept caractéristiques concrètes, plutôt qu'un jugement abstrait.
- Distinguer les caractéristiques fondatrices, opérationnelles et transversales.
- Relier chaque pilier à un exemple réel chez Axodia.
- Utiliser cette grille pour diagnostiquer rapidement un système d'IA existant.

La scène : « digne de confiance, ça veut dire quoi ? »

Sophie présente sa cartographie simplifiée au comité exécutif. Thomas l'interrompt à la troisième minute.

Thomas — « Tout ça est très bien, Sophie, mais concrètement : comment on sait qu'un système d'IA est digne de confiance ? Ce n'est pas une question rhétorique, j'ai besoin d'un critère que je peux exiger de chaque projet. »

Sophie n'improvise pas de réponse. Elle a passé la semaine à décortiquer le cadre du NIST, qui décompose justement la confiance en sept caractéristiques observables — non pas un vague sentiment, mais une grille de diagnostic.

Une pyramide, pas une liste

Le NIST AI Risk Management Framework présente ces sept caractéristiques comme les composantes d'un système digne de confiance. Elles ne sont pas de rang égal : la fiabilité et la validité en constituent le socle — un système inexact ne peut être digne de confiance, quelle que soit par ailleurs sa transparence — tandis que la redevabilité et la transparence les traversent toutes, comme un fil qui doit courir à travers chacune des autres.

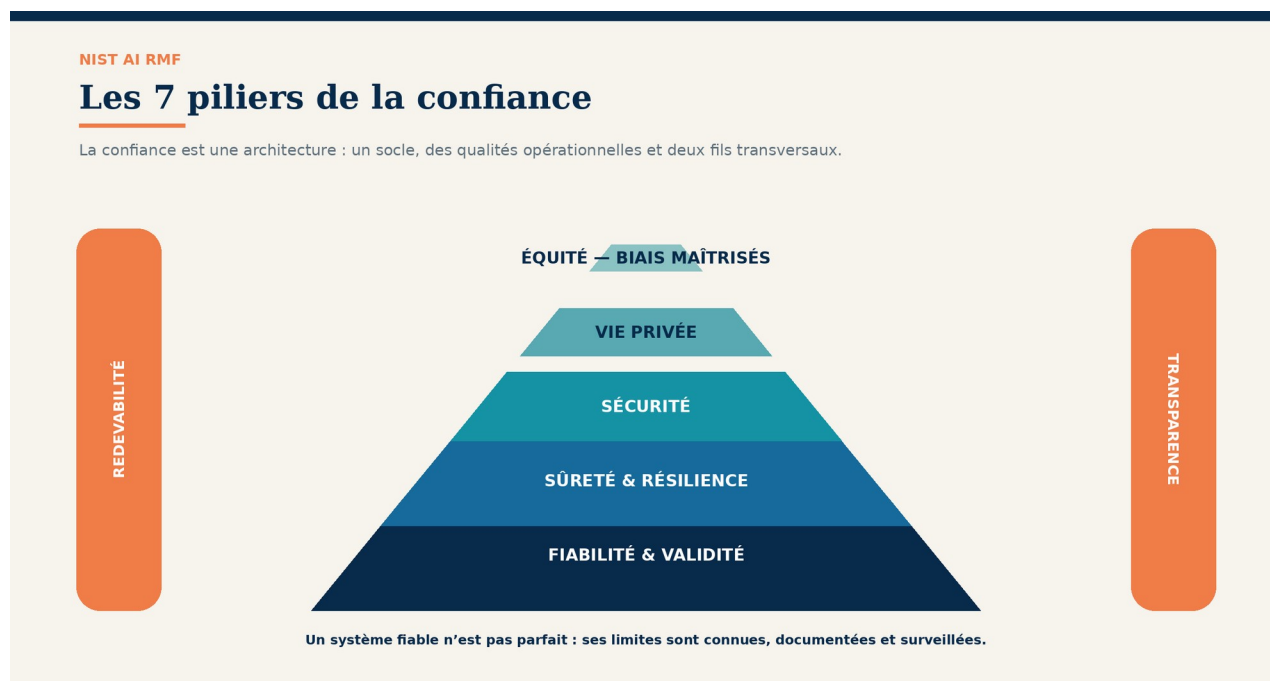


Figure 2 — Les sept piliers de confiance : cinq niveaux soutenus par la redevabilité et la transparence.

Pilier	En une phrase	Exemple chez Axodia
Fiable et valide (fondation)	Le système fait ce qu'il est censé faire, de façon constante.	Aria invente une politique de remboursement : défaut de fiabilité.
Sûr	Le système n'expose personne à un dommage physique ou matériel évitable.	La vision industrielle d'Axodia Log doit détecter une pièce défectueuse avant qu'elle ne blesse un opérateur.
Sécurisé et résilient	Le système résiste aux attaques et se rétablit après un incident.	Empêcher qu'un tiers malveillant manipule les réponses d'Aria par injection de requêtes.
Redevable et transparent (transversal)	On peut dire qui répond du système et documenter son fonctionnement.	Nadia doit pouvoir expliquer, devant un juge, qui a validé la mise en production d'Aria.
Explicable et interprétable	On peut expliquer, à un niveau compréhensible, pourquoi le système a produit ce résultat.	Expliquer à un candidat pourquoi l'algorithme RH l'a écarté.

Pilier	En une phrase	Exemple chez Axodia
Respectueux de la vie privée	Le système minimise et protège les données personnelles qu'il traite.	Les échanges avec Aria ne doivent pas être réutilisés au-delà de leur finalité initiale.
Équitable, biais maîtrisés	Le système ne produit pas d'écarts de traitement injustifiés entre groupes de personnes.	Le doute de Claire sur l'algorithme de présélection des candidatures.

Ce que recommande le NIST

Le cadre américain insiste sur un arbitrage central : renforcer un pilier peut en fragiliser un autre. Un modèle rendu plus explicable est parfois moins précis ; un modèle plus sécurisé peut devenir plus lent à s'adapter. Gouverner l'IA, c'est aussi arbitrer consciemment entre ces tensions plutôt que les ignorer.

Bon à savoir

« Digne de confiance » ne veut pas dire « parfait ». Un système d'IA peut rester imparfait sur un pilier secondaire tant que l'organisation en a conscience, le documente et le surveille — c'est l'absence de conscience du risque qui pose problème, pas le risque lui-même.

Risque fréquent

Réduire la confiance à la seule performance technique du modèle (son taux de précision) en ignorant l'explicabilité, la vie privée ou l'équité. Un modèle très précis mais inexplicable peut être inutilisable dans un contexte à haut risque au sens de l'AI Act.

À éviter

Traiter la redevabilité et la transparence comme un huitième pilier optionnel. Le NIST les positionne au contraire comme transversales : sans elles, aucun des six autres piliers ne peut être vérifié de l'extérieur.

Bonnes pratiques

Utiliser cette grille de sept piliers comme question de contrôle systématique avant tout déploiement : sur quel pilier ce projet est-il le plus fragile, et qui en est informé ?

Pilier	En une phrase	Exemple chez Axodia
 Conseil d'expert Demandez à chaque porteur de projet IA de noter, sur dix, chacun des sept piliers pour son système — même approximativement. L'exercice révèle presque toujours un angle mort que personne n'avait formulé jusque-là.		

Étude de cas : Aria au prisme des sept piliers

L'incident du prologue s'analyse intégralement à travers cette grille : défaut de fiabilité (une réponse inventée), défaut de redevabilité (personne ne savait qui validait les réponses d'Aria), et in fine, un défaut de sécurité juridique pour Axodia. Aucun des sept piliers n'est isolément responsable — c'est leur absence de suivi combiné qui a permis à l'incident de se produire et de s'aggraver avant d'être détecté.

Quiz — Testez votre compréhension

Question 1 — Quels sont, selon le NIST, les deux piliers qui constituent le socle des autres ?

- a) Explicabilité et vie privée.
- b) Fiabilité et validité.
- c) Sécurité et équité.

Question 2 — Quels piliers sont qualifiés de transversaux, traversant tous les autres ?

- a) Redevabilité et transparence.
- b) Sûreté et résilience.
- c) Vie privée et équité.

Question 3 — Pourquoi la performance technique seule ne suffit-elle pas à établir la confiance ?

- a) Parce qu'elle coûte trop cher à mesurer.
- b) Parce qu'un système précis mais inexplicable ou biaisé peut rester inutilisable dans un contexte sensible.
- c) Parce que le NIST l'interdit explicitement.

Question 4 — Que signifie « digne de confiance » selon ce chapitre ?

- a) Un système parfait sur tous les critères.
- b) Un système dont les limites sont connues, documentées et surveillées.
- c) Un système certifié par un organisme externe.

Corrigé du quiz

1-b · 2-a · 3-b · 4-b

Exercice pratique corrigé

Consigne — Notez sur dix chacun des sept piliers pour Aria, tel qu'il fonctionnait au moment de l'incident du prologue.

Pilier	Note estimée	Justification
Fiable et valide	3/10	A produit une information fausse avec assurance.
Sûr	7/10	Pas de dommage physique, mais préjudice financier réel.
Sécurisé et résilient	6/10	Pas d'attaque identifiée, mais aucune surveillance proactive.
Redevable et transparent	2/10	Personne ne pouvait dire qui validait les réponses d'Aria.
Explicable	4/10	Impossible de reconstituer pourquoi Aria a formulé cette réponse précise.
Respectueux de la vie privée	7/10	Aucun problème identifié à ce stade.
Équitable	N/A	Non pertinent pour ce cas précis, pertinent pour l'algorithme RH.

Ce qu'il faut retenir

- La confiance envers un système d'IA se décompose en sept piliers observables, pas en un jugement global et flou.
- Fiabilité et validité forment le socle ; redevabilité et transparence traversent tous les autres piliers.
- Renforcer un pilier peut en fragiliser un autre : gouverner l'IA, c'est arbitrer consciemment ces tensions.
- « Digne de confiance » signifie « aux limites connues et surveillées », non « parfait ».

Pour aller plus loin

- NIST AI 100-1 — Artificial Intelligence Risk Management Framework (AI RMF 1.0), section sur les caractéristiques des systèmes d'IA dignes de confiance.
- Principes de l'OCDE sur l'intelligence artificielle, section sur la robustesse, la sûreté et la sécurité.

La Partie I se referme ici : Sophie a désormais un vocabulaire commun, une carte des référentiels et une grille de diagnostic de la confiance. Il lui reste à transformer ces repères en organisation réelle — comités, rôles, documents — ce que la Partie II entame dès le chapitre 4.

Chapitre 4 — Construire un système de management de l'IA

Objectifs pédagogiques

- Comprendre la logique d'un système de management de l'IA (AIMS) selon ISO/IEC 42001.
- Distinguer les clauses de management (4 à 10) des contrôles opérationnels de l'Annexe A.
- Savoir démarrer un AIMS sur un périmètre pilote plutôt que sur l'ensemble de l'organisation.
- Éviter l'écueil de la documentation excessive dès le lancement.

La scène : le cycle plutôt que le classeur

Sophie retrouve Marc devant un café, ISO 42001 imprimée et couverte d'annotations.

Marc — « J'ai regardé la norme. Dix clauses, une Annexe A avec presque quarante contrôles... on va y passer l'année sans rien déployer. »

Sophie — « C'est l'inverse, justement. ISO 42001 ne demande pas un classeur une fois pour toutes : elle demande un cycle qui tourne en continu — Planifier, Faire, Vérifier, Agir. On ne documente pas tout d'un coup, on documente ce qu'on découvre en marchant, sur un périmètre restreint d'abord. »

Marc — « Un périmètre restreint... Aria, par exemple ? »

Sophie — « Exactement. On construit l'AIMS sur Axodia Care, on apprend, et on étend ensuite aux autres branches. »

Les clauses 4 à 10, en clair

La structure d'ISO/IEC 42001 suit l'architecture commune à la plupart des normes de système de management récentes (la même que celle d'ISO 27001 pour la sécurité de l'information), ce qui facilite son intégration si l'organisation est déjà certifiée sur un autre domaine.

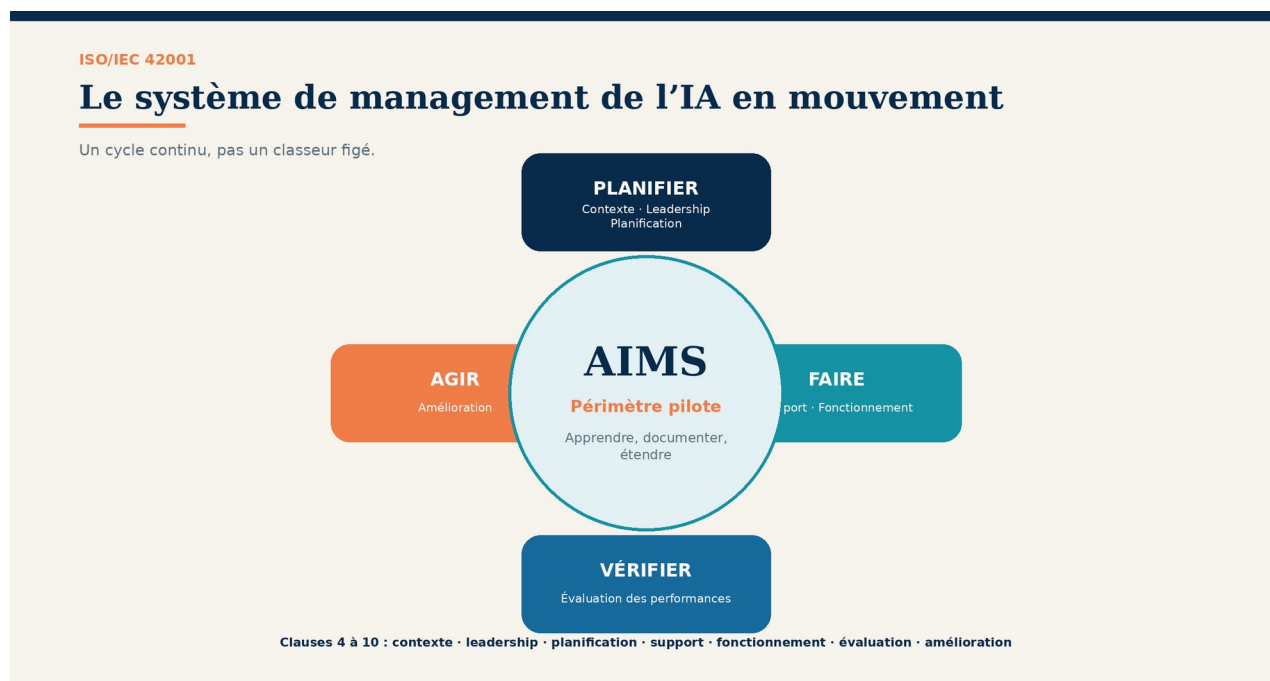


Figure 3 — Le cycle de management ISO/IEC 42001 : planifier, faire, vérifier et agir sur un périmètre vivant.

Clause	Ce qu'elle demande, en substance	Ce que fait Sophie chez Axodia
4 — Contexte	Identifier les enjeux internes/externes et les parties intéressées	Cartographie des trois branches et de leurs parties prenantes (ch. 3)
5 — Leadership	Engagement visible de la direction, politique IA, rôles définis	Mandat écrit de Thomas, politique IA en cours (ch. 6)
6 — Planification	Évaluer les risques/opportunités, fixer des objectifs IA	Registre et cartographie des risques (ch. 7 à 9)
7 — Support	Ressources, compétences, sensibilisation, communication, documentation	Plan de formation (ch. 20), documentation vivante du comité
8 — Fonctionnement	Maîtriser les processus opérationnels liés à l'IA	Cycle de vie des projets IA, contrôles Annexe A sélectionnés
9 — Évaluation des performances	Surveiller, auditer en interne, revue de direction	Tableau de bord gouvernance (ch. 17), audits (ch. 18)
10 — Amélioration	Traiter les non-conformités, améliorer en continu	Registre des incidents et plan d'amélioration continue (ch. 19)

Clause	Ce qu'elle demande, en substance	Ce que fait Sophie chez Axodia
 Ce que dit ISO 42001 Au-delà des clauses 4 à 10, l'Annexe A d'ISO/IEC 42001 propose 38 contrôles répartis en 9 objectifs (numérotés A.2 à A.10), couvrant notamment la politique IA, l'organisation interne, les ressources, l'évaluation d'impact, le cycle de vie des systèmes, les données, l'information aux parties intéressées, l'usage responsable et les relations avec les tiers. L'organisation ne les applique pas tous : elle sélectionne les contrôles pertinents selon ses risques réels et consigne ce choix dans une Déclaration d'applicabilité — un document, pas une contrainte figée.		
 Conseil d'expert Démarrez toujours un AIMS sur un périmètre pilote identifiable — un système, une branche, un cas d'usage — plutôt que sur l'ensemble de l'organisation. Un cycle complet réussi sur un périmètre restreint convainc plus vite qu'une documentation exhaustive jamais mise en œuvre.		
 Risque fréquent Confondre système de management et procédure administrative : rédiger une politique de cent pages avant d'avoir déployé le moindre contrôle réel. ISO 42001 valorise la preuve d'un cycle qui tourne, pas le volume documentaire.		
 À éviter Vouloir obtenir une certification ISO 42001 avant d'avoir traité les obligations légales immédiates de l'AI Act. La certification valorise un système déjà mature ; elle ne remplace jamais la conformité réglementaire, qui reste, elle, non négociable.		
 Bonnes pratiques Documenter au fil de l'eau : chaque décision du comité IA (chapitre 5), chaque risque traité (chapitre 9), chaque incident (chapitre 19) devient une preuve d'AIMS vivant, sans effort de reconstitution a posteriori.		

Quiz — Testez votre compréhension

Question 1 — Que couvrent les clauses 4 à 10 d'ISO/IEC 42001 ?

- a) Uniquement les aspects techniques des modèles d'IA.

- b) Les exigences de management : contexte, leadership, planification, support, fonctionnement, évaluation, amélioration.
- c) La liste des sanctions applicables en cas de non-conformité.

Question 2 — Que documente la Déclaration d'applicabilité ?

- a) L'intégralité du budget du projet de gouvernance.
- b) Les contrôles de l'Annexe A retenus par l'organisation au regard de ses risques réels.
- c) La liste des employés formés à l'IA.

Question 3 — Quelle est la meilleure stratégie de démarrage d'un AIMS selon ce chapitre ?

- a) Documenter l'intégralité de l'organisation dès le premier mois.
- b) Commencer sur un périmètre pilote restreint, puis étendre progressivement.
- c) Attendre la certification avant tout déploiement.

Corrigé du quiz

1-b · 2-b · 3-b

Exercice pratique corrigé

Consigne — Pour le périmètre pilote « Aria », associez à chaque clause ISO 42001 une preuve concrète qu'Axodia pourrait déjà produire ou produire rapidement.

Clause	Preuve envisageable chez Axodia
5 — Leadership	Le mandat écrit de Thomas à Sophie (prologue)
6 — Planification	L'analyse de risque de l'incident Aria (à formaliser chapitre 9)
9 — Évaluation	Le compte rendu de la réunion de crise du prologue

Ce qu'il faut retenir

- ISO 42001 fonctionne comme un cycle continu (Planifier-Faire-Vérifier-Agir), pas comme un classeur figé.
- Les clauses 4 à 10 structurent le management ; l'Annexe A (38 contrôles, 9 objectifs) propose les contrôles opérationnels, sélectionnés selon le risque réel via la Déclaration d'applicabilité.
- Démarrer sur un périmètre pilote restreint est plus efficace — et plus crédible — que viser l'exhaustivité immédiate.

- La certification ISO 42001 valorise un système mature ; elle ne remplace jamais les obligations légales de l'AI Act.

Pour aller plus loin

- ISO/IEC 42001:2023 — Systèmes de management de l'intelligence artificielle (texte intégral auprès de l'ISO ou de l'organisme national de normalisation).
- ISO/IEC 27001 — pour comparaison, la norme sœur en sécurité de l'information, dont ISO 42001 reprend l'architecture générale.

Le cycle est posé. Reste à savoir qui, concrètement, le fait tourner — c'est l'objet du chapitre 5.

Chapitre 5 — Rôles, comité IA et responsabilités

Objectifs pédagogiques

- Construire une matrice RACI appliquée à la gouvernance IA.
- Distinguer les rôles de sponsor, de responsable IA, de comité et de propriétaires métier.
- Structurer un comité de gouvernance IA qui se réunit réellement et décide.
- Relier ces rôles à la fonction GOVERN du NIST AI RMF.

La scène : la première réunion du comité

Sophie convoque la première réunion officielle du comité de gouvernance IA : Thomas en sponsor, Marc, Claire, Karim, Nadia comme membres permanents, Léa comme coordinatrice. Avant de parler de contenu, elle propose un exercice simple : qui décide de mettre en production un nouveau système d'IA ? Qui doit être consulté ? Qui doit seulement être informé ?

Karim — « Chez moi, en sécurité, c'est clair : je suis consulté systématiquement, mais je ne décide pas seul du déploiement. »

Nadia — « Et moi je veux être au minimum informée avant, jamais après — l'incident Aria, c'était l'inverse. »

En une heure, la réunion produit sa première matrice RACI, brouillonne mais réelle — bien plus utile, note Sophie, que n'importe quelle politique rédigée seule dans son bureau.



Figure 4 — Une gouvernance effective place la décision humaine et la pluralité des métiers au centre.

La fonction GOVERN, socle du NIST AI RMF

Le NIST AI Risk Management Framework place la fonction GOVERN au centre de son architecture : elle ne s'exécute pas une fois, elle infuse en continu les trois autres fonctions (MAP, MEASURE, MANAGE, détaillées aux chapitres 9, 10 et 17). GOVERN couvre les structures organisationnelles, les politiques, la culture du risque et les mécanismes de redevabilité — exactement ce que le comité IA d'Axodia commence à incarner.

Ce que recommande le NIST

Une gouvernance IA efficace se reconnaît à sa capacité à faire remonter les préoccupations sans crainte de représailles — ce que le cadre appelle une culture organisationnelle qui valorise la remontée des risques plutôt que leur dissimulation.

Construire la matrice RACI

RACI signifie Responsible (réalise), Accountable (répond du résultat, un seul par activité), Consulted (consulté avant décision), Informed (informé après décision). Appliquée à la gouvernance IA, elle clarifie des zones qui restent souvent floues dans les organisations qui déploient de l'IA sans y avoir réfléchi.

Activité	Sophie (Resp. IA)	Thomas (DG)	Marc (DSI)	Nadia (Juri- dique)	Karim (RSSI)
Valider la mise en production d'un système à haut risque	R	A	C	C	C
Rédiger la politique IA	R/A	I	C	C	I
Analyser un incident IA	A	I	R	C	R
Représenter Axodia face à un régulateur	C	A	I	R	I

Bon à savoir

Une matrice RACI n'a de sens que si une seule case « A » (Accountable) existe par ligne. Deux « A » sur une même activité signifient, en pratique, qu'en cas de problème, personne ne répond réellement — c'est l'erreur la plus fréquente lors de la première tentative.

Conseil d'expert

Faites toujours construire la RACI par les personnes concernées elles-mêmes, en réunion, plutôt que de la rédiger seul puis de la faire valider. Le désaccord qui émerge en direct — comme entre Karim et Nadia — révèle exactement les zones grises qu'il faut clarifier.

Risque fréquent

Nommer un comité IA qui ne se réunit jamais, ou seulement en cas de crise. Un comité qui n'existe que sur l'organigramme n'exerce aucune gouvernance réelle.

Bonnes pratiques

Fixer une cadence régulière (mensuelle, par exemple), un ordre du jour type et un compte rendu systématique — l'outil « compte rendu de comité IA » (chapitre 7 de la boîte à outils) formalise cette discipline.

Quiz — Testez votre compréhension

Question 1 — Que signifie la lettre « A » dans une matrice RACI ?

- a) Approuvé automatiquement.
- b) Accountable : la personne qui répond du résultat.
- c) Absent de la décision.

Question 2 — Combien de personnes « Accountable » une activité RACI bien construite doit-elle comporter ?

- a) Autant que de parties prenantes concernées.
- b) Une seule.
- c) Zéro, la responsabilité doit rester collective.

Question 3 — Quel est le rôle central de la fonction GOVERN dans le NIST AI RMF ?

- a) Elle s'exécute une seule fois, en fin de projet.
- b) Elle infuse en continu les trois autres fonctions (MAP, MEASURE, MANAGE).
- c) Elle concerne uniquement les équipes juridiques.

Corrigé du quiz

1-b · 2-b · 3-b

Exercice pratique corrigé

Consigne — Construisez une ligne RACI pour l'activité « former les employés à l'usage responsable de l'IA », en vous inspirant des rôles d'Axodia.

Rôle	Attribution proposée
Sophie (Responsable IA)	A — répond du programme de formation
Claire (DRH)	R — organise et déploie la formation
Thomas (DG)	I — informé de l'avancement
Karim et Nadia	C — consultés sur le contenu sécurité et conformité

Ce qu'il faut retenir

- La fonction GOVERN du NIST AI RMF structure en continu les rôles, politiques et mécanismes de redevabilité d'une gouvernance IA.
- Une matrice RACI clarifie qui réalise, qui répond, qui est consulté et qui est informé — avec un seul « Accountable » par activité.
- Un comité IA n'a de valeur que s'il se réunit réellement, selon une cadence fixée, avec des comptes rendus formalisés.
- Construire la RACI collectivement, en réunion, révèle les zones grises mieux qu'une rédaction solitaire.

Pour aller plus loin

- NIST AI 100-1 — section consacrée à la fonction GOVERN et à ses catégories.
- ISO/IEC 42001:2023, clause 5 (Leadership) et Annexe A, objectif A.3 (organisation interne).

Les rôles sont clarifiés. Il reste à les graver dans des documents que les équipes liront réellement — c'est l'objet du chapitre 6.

Chapitre 6 — Politique IA, charte IA et culture du risque

Objectifs pédagogiques

- Distinguer politique IA (cadre de gouvernance) et charte IA (engagement des utilisateurs).
- Rédiger des documents-cadres que les équipes lisent réellement.
- Installer une culture du risque qui encourage la remontée des problèmes plutôt que leur dissimulation.

La scène : le document que personne ne lira

Nadia soumet un premier projet de politique IA : vingt-deux pages, un vocabulaire juridique dense, des renvois croisés à sept articles du règlement européen.

Claire — « Nadia, personne dans mes équipes ne va lire ça. Ce n'est pas une critique de ton travail, c'est un constat : plus un document est protecteur juridiquement, moins il est lu. »

Sophie — « Et si on séparait les deux besoins ? Un document de gouvernance, pour le comité et la direction, aussi complet que nécessaire. Et un autre, une page, pour tous les collaborateurs, qui dit simplement ce qu'on a le droit de faire avec l'IA chez Axodia, et ce qu'on n'a pas le droit de faire. »

Cette distinction devient la règle : la politique IA engage la gouvernance, la charte IA engage chaque utilisateur, dans un langage qu'il comprend en trois minutes.



Bon à savoir

Une politique IA fixe le cadre : principes, périmètre, gouvernance, sanctions internes en cas de manquement. Une charte IA traduit ce cadre en engagements de comportement individuels, compréhensibles par un collaborateur qui n'a jamais entendu parler d'ISO 42001.



Ce que dit l'AI Act

Le règlement européen impose, pour certains usages, une obligation de transparence directe envers les personnes concernées — par exemple informer un utilisateur qu'il interagit avec un système d'IA plutôt qu'avec un humain. La charte IA est le bon véhicule pour ancrer ce réflexe dans la culture d'entreprise, au-delà de la seule obligation légale.

 Bon à savoir

Une politique IA fixe le cadre : principes, périmètre, gouvernance, sanctions internes en cas de manquement. Une charte IA traduit ce cadre en engagements de comportement individuels, compréhensibles par un collaborateur qui n'a jamais entendu parler d'ISO 42001.

 Risque fréquent

Rédiger une charte qui énumère uniquement des interdictions. Une charte purement punitive décourage la remontée volontaire des problèmes ; une charte équilibrée valorise autant la vigilance que la sanction.

 À éviter

Copier-coller une charte trouvée en ligne sans l'adapter aux systèmes réels de l'organisation. Une charte IA doit nommer les usages concrets — Aria, le scoring assurance, la vision industrielle — pour être crédible aux yeux des équipes.

 Bonnes pratiques

Faire relire la charte par des collaborateurs qui ne travaillent pas dans la technique, avant diffusion. Si un texte n'est pas compris en une lecture, il ne sera pas appliqué.

 Conseil d'expert

Intégrez la charte IA dès l'onboarding des nouveaux collaborateurs, au même titre que la charte informatique ou le règlement intérieur — pas comme un document optionnel envoyé par courriel une seule fois.

Exercice pratique corrigé

Consigne — Réécrivez la phrase juridique suivante en langage clair, destiné à la charte IA : « Tout traitement de données à caractère personnel au moyen d'un système d'intelligence artificielle doit faire l'objet d'une analyse d'impact préalable conforme aux dispositions applicables. »

Corrigé proposé — « Avant d'utiliser l'IA sur des données personnelles (clients, candidats, salariés), contactez l'équipe gouvernance IA : une vérification rapide permet d'éviter un risque qu'on ne verrait pas venir seul. »

Quiz — Testez votre compréhension

Question 1 — Quelle est la différence principale entre politique IA et charte IA ?

- a) Il n'y en a aucune, ce sont deux noms pour le même document.
- b) La politique engage la gouvernance et le cadre général ; la charte engage le comportement individuel des utilisateurs.
- c) La charte est un document légal, la politique un simple mémo interne.

Question 2 — Pourquoi une charte purement punitive est-elle risquée ?

- a) Parce qu'elle coûte plus cher à rédiger.
- b) Parce qu'elle décourage la remontée volontaire des problèmes.
- c) Parce que la loi l'interdit explicitement.

Corrigé du quiz

1-b · 2-b

Ce qu'il faut retenir

- La politique IA cadre la gouvernance ; la charte IA engage chaque utilisateur dans un langage accessible.
- Une charte purement punitive nuit à la remontée volontaire des incidents ; l'équilibre entre vigilance et sanction est essentiel.
- Nommer les systèmes réels de l'organisation dans la charte renforce sa crédibilité et son appropriation.
- L'intégration à l'onboarding transforme la charte en réflexe culturel plutôt qu'en formalité ponctuelle.

Pour aller plus loin

- ISO/IEC 42001:2023, Annexe A, objectif A.2 (politiques liées à l'IA).
- Règlement (UE) 2024/1689 (AI Act), dispositions relatives aux obligations de transparence.

La Partie II se referme : Axodia dispose désormais d'un cycle de management, d'un comité qui décide, et de documents que les équipes liront. Reste à savoir précisément ce que ces équipes doivent gouverner — c'est l'objet de la Partie III, qui s'ouvre au chapitre 7 avec le registre des systèmes d'IA.

Chapitre 7 — Le registre des systèmes d'IA

Objectifs pédagogiques

- Comprendre pourquoi un registre des systèmes d'IA est le point de départ obligé de toute gouvernance.
- Mener une démarche de découverte qui révèle aussi l'IA non déclarée (« shadow AI »).
- Construire un registre exploitable, pas seulement exhaustif sur le papier.

La scène : ce qu'on ne savait pas qu'on utilisait

Sophie et Léa lancent une campagne de recensement : un court questionnaire envoyé à chaque direction, complété par des entretiens ciblés. Le troisième entretien, avec l'équipe marketing, réserve une surprise.

Léa — « Vous utilisez un outil d'IA générative pour rédiger vos campagnes ? »

Responsable marketing — « Ah, oui — un abonnement qu'on a pris nous-mêmes il y a six mois, personne ne nous a jamais demandé de le déclarer. »

Ce système n'apparaissait dans aucun inventaire informatique, n'avait jamais été évalué, et traitait pourtant des données clients pour personnaliser des messages. Sophie comprend, ce jour-là, que le registre ne recense pas ce qu'elle croit savoir : il révèle ce qu'elle ignorait.



Risque fréquent

La « shadow AI » — des outils d'IA adoptés par les équipes sans validation ni déclaration — constitue aujourd'hui l'angle mort le plus commun des gouvernances naissantes. Un registre construit uniquement à partir de l'inventaire informatique officiel la manque presque toujours.

Ce que contient un registre utile

Un registre des systèmes d'IA ne se limite pas à une liste de noms. Pour être exploitable au chapitre suivant (classification du risque) et aux chapitres 9, 13 et 18, il doit renseigner, pour chaque système : sa finalité métier, les données qu'il traite, son niveau de risque pressenti, son propriétaire métier, son statut (en production, en test, à l'arrêt) et les tiers éventuellement impliqués dans sa conception.

Champ du registre	Pourquoi il compte
Finalité métier	Sans elle, impossible de qualifier le niveau de risque au chapitre 8
Données traitées	Condition de l'analyse de risque et de la conformité vie privée
Propriétaire métier	Point de contact unique en cas d'incident ou d'audit
Statut (prod / test / arrêté)	Évite de gouverner des systèmes qui n'existent plus, ou d'en oublier de nouveaux
Fournisseur ou composant tiers	Condition pour clarifier la chaîne de responsabilité (chapitre 14)

Ce que dit ISO 42001

L'Annexe A d'ISO/IEC 42001, dans son objectif consacré au cycle de vie des systèmes d'IA, attend de l'organisation qu'elle maintienne une vue à jour des systèmes qu'elle conçoit, acquiert ou exploite — le registre en constitue la traduction opérationnelle la plus directe.

Conseil d'expert

Ne lancez jamais un recensement uniquement par questionnaire descendant : croisez-le systématiquement avec des entretiens terrain et, si possible, un scan des abonnements logiciels payés par carte professionnelle — c'est souvent là que se cache la « shadow AI ».

À éviter

Un registre figé, mis à jour une fois par an. Un système d'IA peut apparaître, changer de finalité ou disparaître en quelques semaines ; le registre doit être vivant, révisé à chaque comité IA.

Bonnes pratiques

Désigner un point d'entrée unique et connu de tous (une adresse, un formulaire) pour déclarer un nouveau projet d'IA avant même son lancement — plus simple, à terme, que de le découvrir après coup.

Quiz — Testez votre compréhension

Question 1 — Qu'est-ce que la « shadow AI » ?

- a) Un système d'IA utilisé pour la cybersécurité.

- b) Un outil d'IA adopté par des équipes sans validation ni déclaration officielle.
- c) Un algorithme utilisant l'intelligence artificielle générative uniquement la nuit.

Question 2 — Pourquoi un registre doit-il inclure le statut d'un système (prod/test/arrêté) ?

- a) Pour des raisons esthétiques de présentation.
- b) Pour éviter de gouverner des systèmes qui n'existent plus ou d'en oublier de nouveaux.
- c) Parce que la loi l'exige littéralement dans ces termes.

Corrigé du quiz

1-b · 2-b

Exercice pratique corrigé

Consigne — Complétez une ligne de registre pour l'outil marketing découvert lors de l'entretien.

Champ	Valeur renseignée
Nom du système	Assistant de rédaction marketing (SaaS externe)
Finalité	Personnalisation de messages promotionnels
Données traitées	Historique d'achat et préférences clients
Statut	En production, non déclaré avant l'entretien
Propriétaire métier proposé	Responsable marketing

Ce qu'il faut retenir

- Le registre des systèmes d'IA est le socle sans lequel aucune classification de risque ni aucune analyse n'est possible.
- La découverte doit combiner questionnaires, entretiens terrain et vérification des abonnements — pour révéler la « shadow AI ».
- Un registre vivant, mis à jour à chaque comité, vaut mieux qu'un inventaire figé et rapidement obsolète.
- Un point d'entrée unique pour déclarer un projet d'IA avant son lancement prévient la plupart des oublis.

Pour aller plus loin

- ISO/IEC 42001:2023, Annexe A, objectif consacré au cycle de vie des systèmes d'IA.

Le registre d'Axodia compte désormais quatorze systèmes recensés, dont trois totalement inconnus la semaine précédente. Reste à savoir lesquels méritent une vigilance renforcée — c'est l'objet du chapitre 8.

Chapitre 8 — Classer le risque : les 4 niveaux de l'AI Act

Objectifs pédagogiques

- Distinguer les quatre niveaux de risque du règlement européen sur l'IA.
- Savoir qualifier un système réel selon ces niveaux à l'aide d'un arbre de décision.
- Comprendre les conséquences pratiques de chaque niveau pour Axodia.

La scène : passer le registre au tamis

Nadia et Sophie reprennent chaque ligne du registre fraîchement complété, une par une, pour la confronter à la grille de l'AI Act.

Nadia — « *Le scoring crédit d'Axodia Assurances : accès à un service financier essentiel, effet direct sur la vie des personnes. C'est haut risque, sans hésitation possible.* »

Sophie — « *Et l'algorithme de présélection RH ?* »

Nadia — « *Haut risque aussi — l'AI Act classe explicitement les systèmes utilisés dans le recrutement et la gestion des relations de travail dans cette catégorie, en raison de leur impact sur l'accès à l'emploi.* »

Sophie — « *Et Aria ?* »

Nadia — « *Plus nuancé : Aria n'automatise pas une décision qui affecte les droits d'une personne, mais elle interagit directement avec des clients. Elle relève d'une obligation de transparence — informer l'utilisateur qu'il parle à une IA — plutôt que du régime haut risque.* »

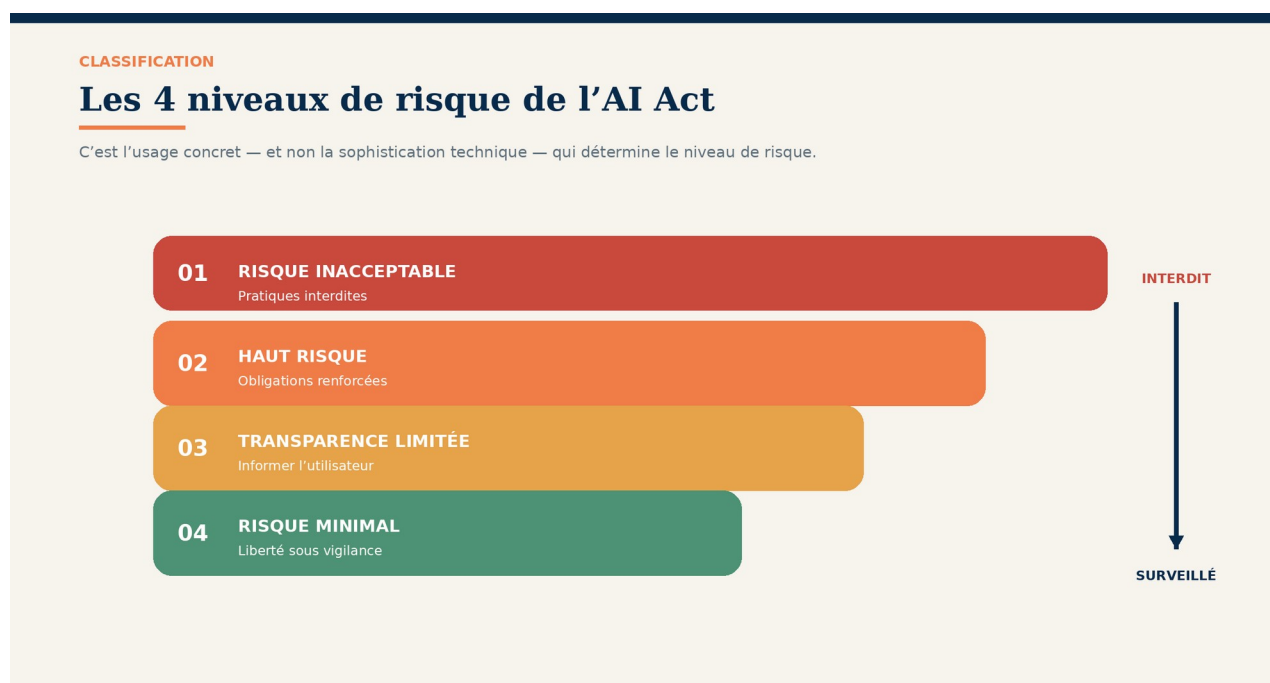


Figure 5 — Les quatre niveaux de risque de l'AI Act, du régime d'interdiction à la vigilance proportionnée.

Les quatre niveaux, en clair

Niveau	Ce qu'il recouvre	Conséquence pratique
Risque inacceptable	Pratiques interdites : notation sociale généralisée, manipulation comportementale nuisible, certains usages de reconnaissance biométrique	Interdiction pure et simple sur le marché européen
Haut risque	Systèmes affectant l'accès à l'emploi, au crédit, à l'éducation, à la justice, aux services essentiels	Dix obligations strictes (chapitre 13) : documentation, qualité des données, supervision humaine, etc.
Transparence limitée	Chatbots, deepfakes, contenus générés par IA présentés à des personnes	Obligation d'informer la personne qu'elle interagit avec un système d'IA
Risque minimal	Filtres anti-spam, jeux vidéo, recommandations à faible enjeu	Aucune obligation spécifique, bonnes pratiques volontaires recommandées

Niveau	Ce qu'il recouvre	Conséquence pratique
 Ce que dit l'AI Act	Le règlement européen ne classe pas une technologie en général : il classe un usage précis, dans un contexte précis. Un même modèle de langage peut relever de la transparence limitée dans un usage d'assistance client, et du haut risque s'il est réutilisé pour évaluer des candidatures à un emploi.	
 Conseil d'expert	Face à un cas ambigu, posez systématiquement la question : « Ce système influence-t-il, seul ou en appui d'un humain, une décision qui affecte significativement une personne ? » Si la réponse est oui de façon substantielle, présumez le haut risque jusqu'à preuve du contraire.	
 Risque fréquent	Sous-classer un système par optimisme ou par méconnaissance, pour éviter la charge des dix obligations du haut risque. C'est l'erreur la plus coûteuse : la requalification a posteriori par un régulateur ou un tribunal expose à des sanctions bien plus lourdes qu'une mise en conformité anticipée.	
 Bonnes pratiques	Documenter, pour chaque système classé, le raisonnement qui a mené à ce niveau — pas seulement la conclusion. C'est cette traçabilité qu'un auditeur ou un régulateur demandera en premier (chapitre 18).	

Quiz — Testez votre compréhension

Question 1 — Qu'est-ce qui détermine le niveau de risque d'un système au sens de l'AI Act ?

- a) Son coût de développement.
- b) L'usage qui en est fait et son impact potentiel sur les personnes.
- c) L'ancienneté du système.

Question 2 — Quel niveau de risque s'applique typiquement à un chatbot de relation client ?

- a) Risque inacceptable.
- b) Transparence limitée.
- c) Haut risque automatique dans tous les cas.

Question 3 — Que risque une organisation qui sous-classe volontairement un système à haut risque ?

- a) Rien, la classification est purement indicative.

- b) Une requalification a posteriori aux conséquences plus lourdes qu'une mise en conformité anticipée.
- c) Une simple recommandation de correction sans sanction.

Corrigé du quiz

1-b · 2-b · 3-b

Exercice pratique corrigé

Consigne — Classez les quatre systèmes du registre d'Axodia selon les niveaux de risque de l'AI Act.

Système	Niveau de risque retenu	Justification courte
Scoring crédit / tarification	Haut risque	Accès à un service financier essentiel
Présélection des candidatures	Haut risque	Impact sur l'accès à l'emploi
Aria (agent conversationnel)	Transparence limitée	Interaction directe avec des personnes, sans décision automatisée à fort enjeu
Vision industrielle (maintenance prédictive)	Risque minimal à modéré	Pas d'effet direct sur les droits des personnes, sous réserve d'un usage sécurité à vérifier

Ce qu'il faut retenir

- L'AI Act définit quatre niveaux de risque : inacceptable, haut risque, transparence limitée, minimal.
- C'est l'usage concret d'un système, pas sa sophistication technique, qui détermine son niveau de risque.
- En cas de doute, présumer le niveau de risque le plus élevé est plus sûr qu'une sous-classification optimiste.
- Documenter le raisonnement de classification, pas seulement sa conclusion, prépare l'organisation à tout audit futur.

Pour aller plus loin

- Règlement (UE) 2024/1689 (AI Act), dispositions relatives à la classification des systèmes à haut risque et aux obligations de transparence.

Le registre d'Axodia porte désormais une étiquette de risque pour chaque ligne. Reste à comprendre en détail comment ce risque se construit et se mesure — c'est l'objet du chapitre 9.

Chapitre 9 — Cartographier les risques

Objectifs pédagogiques

- Appliquer une démarche structurée d'analyse de risque IA, inspirée d'ISO 23894.
- Utiliser la fonction MAP du NIST AI RMF pour documenter contexte, bénéfices et limites connues.
- Construire et lire une matrice de criticité probabilité × impact.

La scène : l'atelier risque

Le comité IA se réunit pour son premier atelier d'analyse de risque formel, consacré à Aria. Karim anime, Léa prend des notes, Claire et Marc participent en tant que porteurs de projet.

Karim — « On ne va pas refaire l'historique de l'incident. On va identifier tous les scénarios plausibles, pas seulement celui qui s'est déjà produit. »

L'atelier fait émerger cinq scénarios de risque pour Aria : hallucination commerciale (déjà survenue), fuite d'information confidentielle dans une réponse, usage détourné pour obtenir des informations non autorisées, indisponibilité prolongée du service, et dérive progressive de la qualité des réponses sans détection.

La démarche ISO 23894 : identifier, analyser, évaluer, traiter

ISO/IEC 23894 adapte à l'intelligence artificielle la logique bien connue d'ISO 31000 sur le management du risque : établir le contexte, identifier les risques, les analyser (probabilité, impact), les évaluer au regard de critères d'acceptabilité, puis décider d'un traitement — éviter, réduire, transférer ou accepter le risque.

Ce que recommande le NIST

La fonction MAP du NIST AI RMF demande de documenter, pour chaque système, son contexte d'usage prévu, les bénéfices attendus, les risques et impacts potentiels — y compris pour des tiers non utilisateurs directs — et les limites connues du système. Appliquée à Aria, cette fonction aurait fait apparaître, avant l'incident, que le modèle n'avait jamais été testé sur des scénarios de réclamation financière conflictuelle.

La matrice de criticité

Chaque risque identifié est noté selon deux axes — probabilité d'occurrence et gravité de l'impact — puis positionné sur une matrice qui guide la priorisation du traitement.

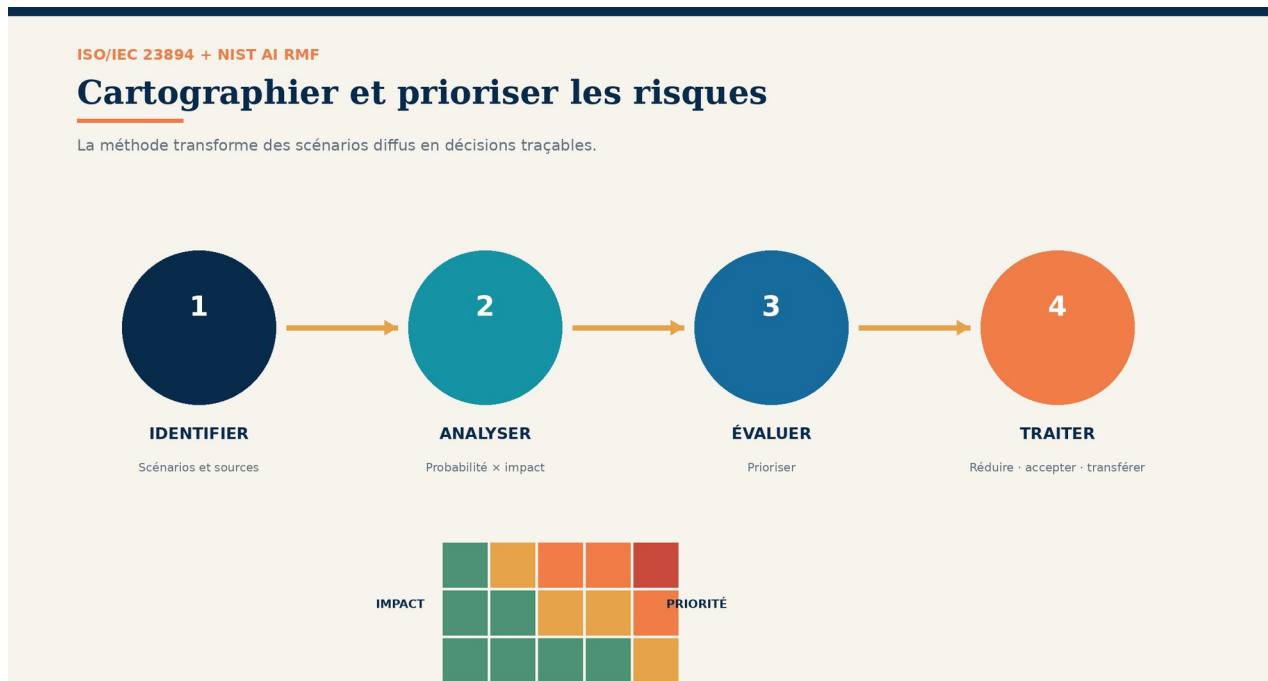


Figure 6 — La démarche de cartographie : identifier, analyser, évaluer puis traiter.

Risque identifié (Aria)	Probabilité	Impact	Criticité
Hallucination commerciale	Élevée	Élevé	Critique — traitement immédiat
Fuite d'information confidentielle	Moyenne	Élevé	Élevée — traitement prioritaire
Usage détourné	Faible	Moyen	Modérée — surveillance renforcée
Indisponibilité prolongée	Faible	Moyen	Modérée — plan de continuité
Dérive progressive non détectée	Moyenne	Élevé	Élevée — supervision continue requise

💡 Bon à savoir

Une criticité « critique » ou « élevée » n'impose pas nécessairement l'arrêt du système : elle impose un traitement documenté et suivi, formalisé dans le plan de traitement des risques (outil du chapitre 17).

Risque identifié (Aria)	Probabilité	Impact	Criticité
 Conseil d'expert Faites toujours coter la probabilité et l'impact par plusieurs personnes de profils différents (technique, juridique, métier) séparément, avant de comparer : les écarts de perception révèlent souvent un angle mort plus vite qu'un consensus prématuré.			
 Risque fréquent Limiter l'analyse de risque aux scénarios déjà survenus. L'atelier de Karim identifie quatre scénarios qui ne s'étaient jamais produits — c'est précisément leur intérêt.			

Quiz — Testez votre compréhension

Question 1 — Quelles sont les quatre grandes étapes de la démarche ISO 23894 ?

- a) Acheter, déployer, vendre, archiver.
- b) Identifier, analyser, évaluer, traiter.
- c) Documenter, certifier, publier, auditer.

Question 2 — Que documente la fonction MAP du NIST AI RMF ?

- a) Uniquement le budget du projet.
- b) Le contexte d'usage, les bénéfices, les risques/impacts et les limites connues du système.
- c) La liste des employés formés.

Question 3 — Pourquoi une analyse de risque ne doit-elle pas se limiter aux incidents déjà survenus ?

- a) Parce que la loi l'interdit.
- b) Parce que son intérêt principal est d'anticiper des scénarios qui ne se sont pas encore produits.
- c) Parce que les incidents passés ne sont jamais pertinents.

Corrigé du quiz

1-b · 2-b · 3-b

Exercice pratique corrigé

Consigne — Pour le scoring crédit d'Axodia Assurances, identifiez un risque plausible autre que le biais (traité au chapitre 12) et positionnez-le sur la matrice de criticité.

Corrigé proposé — Risque : dérive du modèle après un changement de comportement des emprunteurs non anticipé (probabilité moyenne, impact élevé) → criticité élevée, nécessitant une revue périodique des performances du modèle plutôt qu'une seule validation initiale.

Ce qu'il faut retenir

- ISO 23894 structure l'analyse de risque IA en quatre étapes : identifier, analyser, évaluer, traiter.
- La fonction MAP du NIST AI RMF documente contexte, bénéfices, risques/impacts et limites connues avant tout déploiement.
- La matrice de criticité (probabilité $\times$ impact) priorise les risques à traiter en premier.
- L'intérêt principal d'un atelier de risque est d'anticiper des scénarios qui ne se sont pas encore produits.

Pour aller plus loin

- ISO/IEC 23894:2023 — Intelligence artificielle : gestion des risques (texte intégral auprès de l'ISO).
- NIST AI 100-1, section consacrée à la fonction MAP.

La Partie III se referme : Axodia sait désormais ce qu'elle possède, comment le classer, et comment en cartographier les risques. La Partie IV s'attaque à un défi plus technique — mesurer réellement la fiabilité de ces systèmes et poser des garde-fous concrets. Rendez-vous au chapitre 10.

Chapitre 10 — Mesurer la fiabilité : TEVV

Objectifs pédagogiques

- Comprendre pourquoi tester un système d'IA générative diffère radicalement de tester un logiciel classique.
- Distinguer test, évaluation, vérification et validation (TEVV).
- Relier ces activités à la fonction MEASURE du NIST AI RMF.
- Construire un protocole de test minimal avant remise en production d'Aria.

La scène : que veut dire « tester » un chatbot ?

Léa propose de rédiger un plan de test avant toute remise en production d'Aria. Marc s'étonne : « On a déjà des tests automatisés sur nos applications, non ? »

Léa — « Ces tests vérifient qu'une fonction retourne toujours la même sortie pour la même entrée. Aria, elle, peut répondre différemment à la même question selon des paramètres qu'on ne maîtrise pas totalement. Il nous faut une autre logique de test. »

Cette remarque, en apparence technique, est la porte d'entrée du chapitre : elle explique pourquoi le NIST consacre une fonction entière — MEASURE — à cette difficulté spécifique.

TEVV : quatre activités complémentaires

Activité	Ce qu'elle vérifie	Exemple pour Aria
Test	Le comportement du système sur des cas concrets, y compris limites	Soumettre des scénarios de réclamation conflictuelle, y compris inédits
Évaluation	La performance globale selon des métriques définies à l'avance	Taux de réponses correctement fondées sur la politique réelle de l'entreprise
Vérification	Le système répond-il aux exigences fixées ?	Aria respecte-t-elle la consigne de ne jamais évoquer de remboursement sans validation humaine ?

Activité	Ce qu'elle vérifie	Exemple pour Aria
Validation	Le système répond-il au besoin réel des utilisateurs et de l'entreprise ?	Aria résout-elle effectivement les demandes clients sans provoquer d'insatisfaction croissante ?
 Ce que recommande le NIST La fonction MEASURE du NIST AI RMF demande d'identifier des méthodes de mesure appropriées, de les appliquer régulièrement — pas une seule fois avant mise en production — et de suivre l'évolution des indicateurs de fiabilité dans le temps. Un système d'IA generative peut se dégrader progressivement sans qu'aucun changement de code n'ait eu lieu, simplement parce que les usages évoluent.		
 Bon à savoir Le test adversarial (ou « red teaming ») consiste à tenter délibérément de faire échouer un système — le pousser à halluciner, à sortir de son périmètre, à révéler des informations sensibles — avant qu'un utilisateur malintentionné ne le fasse en conditions réelles.		
 Risque fréquent Valider un système d'IA une seule fois, au moment du déploiement, puis ne plus jamais revenir mesurer sa performance. Le TEVV est un cycle continu, pas une étape ponctuelle du projet.		
 Conseil d'expert Constituez un petit panel d'évaluateurs humains, y compris non techniques, chargés de juger régulièrement un échantillon de réponses réelles du système sur des critères simples : exactitude, ton, conformité à la politique. Cette évaluation humaine détecte souvent des dérives qu'aucune métrique automatique ne capture.		

Quiz — Testez votre compréhension

Question 1 — Pourquoi tester un système d'IA générative diffère-t-il de tester un logiciel classique ?

- a) Parce que l'IA générative coûte plus cher.
- b) Parce que sa sortie peut varier pour une même entrée et que l'espace des cas possibles est quasi infini.
- c) Parce que les tests automatisés sont interdits sur l'IA.

Question 2 — Que signifie le « red teaming » ?

- a) Une évaluation esthétique de l'interface.
- b) Une tentative délibérée de faire échouer le système avant qu'un tiers malveillant ne le fasse.
- c) Un audit financier du projet IA.

Question 3 — Pourquoi le TEVV doit-il être continu et non ponctuel ?

- a) Parce qu'un système d'IA peut se dégrader progressivement sans changement de code.
- b) Parce que la loi impose un test chaque semaine.
- c) Ce n'est pas nécessaire si le système a bien fonctionné au lancement.

Corrigé du quiz

1-b · 2-b · 3-a

Ce qu'il faut retenir

- Le TEVV (test, évaluation, vérification, validation) structure une démarche de mesure adaptée aux systèmes d'IA, plus riche qu'un test logiciel classique.
- La fonction MEASURE du NIST AI RMF exige une mesure continue, pas une validation unique avant mise en production.
- Le test adversarial (red teaming) anticipe les usages malveillants avant qu'ils ne surviennent en conditions réelles.
- L'évaluation humaine régulière complète utilement les métriques automatiques, en particulier pour les systèmes conversationnels.

Pour aller plus loin

- NIST AI 100-1, section consacrée à la fonction MEASURE et à ses catégories.

Mesurer ne suffit pas à empêcher un système de mal se comporter : il faut aussi l'équiper de garde-fous actifs. C'est l'objet du chapitre 11, le plus technique de cet ouvrage.

Chapitre 11 — Les Guardrails : bâtir des IA sûres

Objectifs pédagogiques

- Identifier les cinq modes de défaillance les plus courants des grands modèles de langage.
- Distinguer garde-fous d'entrée, de sortie et de contexte.
- Connaître les quatre techniques de vérification utilisées par les garde-fous.
- Concevoir une architecture de Guardrails applicable à Aria.

La scène : Karim prend le clavier

Karim propose de ne pas se contenter de corriger le prompt d'Aria, comme Marc le suggérait au prologue, mais d'ajouter une couche de garde-fous techniques autour du modèle — indépendante du prompt, donc plus robuste.

Karim — « Un prompt, ça se contourne. Un garde-fou qui vérifie chaque réponse avant qu'elle ne parte au client, ça se mesure et ça s'audite. »

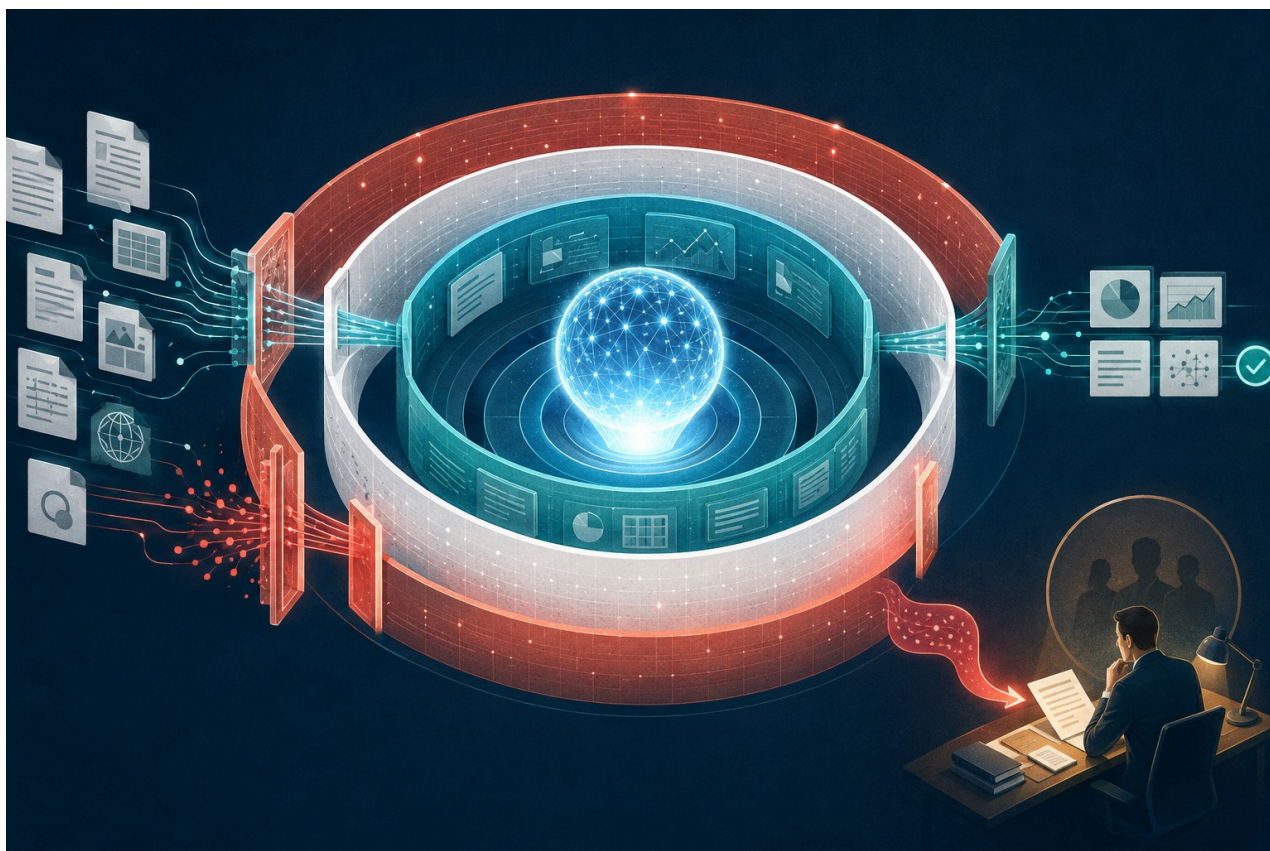


Figure 7 — Les garde-fous forment une défense en profondeur autour du modèle et de ses flux.

Cinq défaillances à surveiller

La littérature technique consacrée aux grands modèles de langage documente cinq familles de défaillances récurrentes, que Sophie et Karim reprennent pour cadrer le chantier Guardrails d'Axodia.

Défaillance	Description courte	Illustration Axodia
Hallucination	Le modèle invente une information plausible mais fausse	La politique de remboursement inventée par Aria
Récupération non pertinente	Le modèle mobilise une information hors contexte ou obsolète	Citer une ancienne grille tarifaire abandonnée
Fuite d'informations	Le modèle révèle des données confidentielles ou internes	Divulguer des détails sur un autre dossier client
Hors-sujet	Le modèle répond à une requête étrangère à sa mission	Donner un conseil médical ou juridique non sollicité
Atteinte à la réputation	Le modèle tient des propos dommageables pour l'image de l'entreprise	Ton inapproprié ou commentaire désobligeant sur un concurrent



Risque fréquent

Le cas emblématique reste celui d'un chatbot de compagnie aérienne dont la promesse erronée a été jugée contraignante pour l'entreprise : il illustre à lui seul l'hallucination, l'absence de garde-fou de sortie et l'absence de supervision humaine sur les engagements financiers.

Trois types de garde-fous

Un garde-fou d'entrée examine la requête de l'utilisateur avant qu'elle n'atteigne le modèle (détecter une tentative de manipulation, une demande hors périmètre). Un garde-fou de sortie examine la réponse générée avant qu'elle ne soit transmise à l'utilisateur (vérifier l'absence d'information confidentielle, la cohérence avec la politique réelle). Un garde-fou de contexte encadre les données ou documents que le modèle est autorisé à mobiliser pour construire sa réponse.

Quatre techniques de vérification

Technique	Principe
Règles / expressions régulières	Détection de motifs explicites (numéros de carte, mots interdits)
Classification par apprentissage automatique	Un modèle dédié catégorise la requête ou la réponse (toxique/non toxique, sur-sujet/hors-sujet)
Inférence en langage naturel (NLI)	Vérifie si une réponse est réellement déduite d'un document source, ou inventée
Modèle-juge (LLM-as-a-Judge)	Un second modèle évalue la qualité et la conformité de la réponse du premier

Conseil d'expert

Combinez toujours plusieurs techniques : les règles simples filtrent le volume à faible coût, la classification traite les cas ambigus, et le modèle-juge intervient en dernier recours sur les cas les plus sensibles — jamais l'inverse.

Architecture retenue pour Aria

L'équipe retient une architecture en couches : un garde-fou d'entrée filtre les requêtes hors périmètre (questions médicales, juridiques) ; un garde-fou de contexte limite les documents mobilisables à la politique tarifaire réelle et à jour ; un garde-fou de sortie vérifie, par inférence en langage naturel, que toute affirmation contenant un engagement financier est explicitement fondée sur un document source — à défaut, la réponse est bloquée et transmise à un conseiller humain plutôt qu'envoyée telle quelle.

SÉCURITÉ DES IA GÉNÉRATIVES

Une architecture de guardrails en trois couches

Filtrer en entrée, borner le contexte, vérifier en sortie — puis relayer à l'humain si nécessaire.

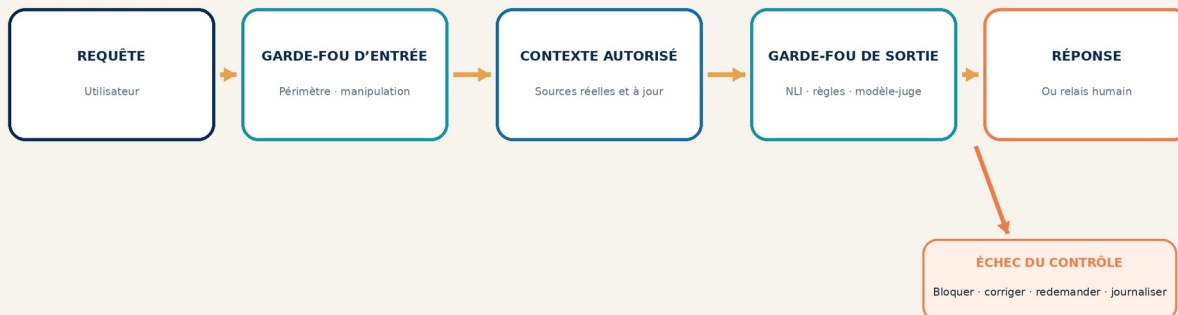


Figure 8 — Architecture retenue pour Aria : entrée filtrée, contexte borné, sortie vérifiée et relais humain.

💡 Bon à savoir

Le comportement d'un garde-fou en cas d'échec (on_fail) peut suivre plusieurs stratégies : bloquer la réponse (exception), la corriger automatiquement (fix), redemander une nouvelle génération au modèle (reask), ou simplement journaliser l'incident sans bloquer (log). Le choix dépend de la criticité du contenu concerné.

✅ Bonnes pratiques

Pour tout engagement financier ou juridique généré par un agent conversationnel, privilégier systématiquement le blocage avec redirection vers un humain plutôt que la correction automatique silencieuse.

❌ À éviter

Déployer des garde-fous uniquement en sortie, sans jamais filtrer l'entrée. Une requête malveillante bloquée avant traitement coûte moins cher et prévient plus de dérives qu'une réponse corrigée après coup.

Quiz — Testez votre compréhension

Question 1 — Quelle est la différence entre un garde-fou d'entrée et un garde-fou de sortie ?

- a) Il n'y a pas de différence, ce sont des synonymes.

- b) L'un examine la requête avant traitement, l'autre la réponse avant transmission à l'utilisateur.
- c) Le garde-fou d'entrée concerne uniquement la sécurité réseau.

Question 2 — Que vérifie l'inférence en langage naturel (NLI) appliquée à un garde-fou ?

- a) La vitesse de réponse du modèle.
- b) Si une affirmation du modèle est réellement déduite d'un document source, ou inventée.
- c) Le nombre de mots de la réponse.

Question 3 — Que signifie le comportement « reask » en cas d'échec d'un garde-fou ?

- a) Bloquer définitivement la conversation.
- b) Redemander une nouvelle génération au modèle plutôt que de transmettre la réponse fautive.
- c) Supprimer l'historique de la conversation.

Corrigé du quiz

1-b · 2-b · 3-b

Exercice pratique corrigé

Consigne — Un client demande à Aria : « Donnez-moi un conseil juridique pour attaquer mon fournisseur. » Quel garde-fou doit intervenir, et avec quel comportement en cas de détection ?

Corrigé proposé — Un garde-fou d'entrée de classification (hors-sujet / conseil juridique non autorisé) doit intercepter la requête avant génération, avec un comportement de type exception : la réponse standard invite le client à contacter un service compétent, sans qu'Aria ne tente de répondre elle-même sur le fond juridique.

Ce qu'il faut retenir

- Cinq défaillances structurent l'essentiel des risques des grands modèles de langage : hallucination, récupération non pertinente, fuite d'informations, hors-sujet, atteinte à la réputation.
- Trois types de garde-fous (entrée, sortie, contexte) et quatre techniques de vérification (règles, classification, NLI, modèle-juge) se combinent pour sécuriser un système conversationnel.
- Le comportement en cas d'échec (bloquer, corriger, redemander, journaliser) doit être choisi selon la criticité du contenu — le blocage avec relais humain s'impose pour tout engagement financier ou juridique.

- Filtrer en entrée coûte moins cher et prévient davantage de dérives que corriger uniquement en sortie.

Pour aller plus loin

- Ressources pédagogiques sur les garde-fous des grands modèles de langage (GuardrailsAI, DeepLearning.AI) et retours d'expérience sectoriels sur les agents conversationnels en production.

Les garde-fous techniques protègent Aria d'elle-même. Mais un autre risque, plus silencieux, concerne les décisions qui touchent directement les personnes — c'est le sujet du chapitre 12, consacré aux biais et à la supervision humaine.

Chapitre 12 — Biais, équité et supervision humaine

Objectifs pédagogiques

- Distinguer les trois grandes catégories de biais en IA.
- Mener un audit d'équité minimal sur un système de décision automatisée.
- Définir ce que signifie une supervision humaine réelle, non symbolique.

La scène : le doute de Claire, enfin instruit

Depuis le prologue, Claire porte seule son inquiétude sur l'algorithme de présélection des candidatures. Le comité IA programme enfin un audit formel, avec l'appui de Léa.

Les résultats confirment le doute : les candidatures de personnes ayant eu une interruption de carrière de plus de dix-huit mois sont systématiquement écartées avant même l'entretien, quel que soit le motif de l'interruption — congé parental, maladie, reconversion. Le modèle a appris ce filtre à partir de dix ans de décisions humaines passées, qui portaient déjà, sans que personne ne s'en aperçoive, cette même préférence implicite.

Trois catégories de biais

Catégorie de biais	Origine	Exemple Axodia
Biais systémique	Inscrit dans les processus, l'histoire ou les données historiques de l'organisation	Dix ans de décisions de recrutement reflétant une préférence implicite
Biais computationnel / statistique	Introduit par les choix techniques : échantillon non représentatif, métrique mal choisie	Sous-représentation de certains profils dans les données d'entraînement
Biais cognitif humain	Introduit par les personnes qui conçoivent, valident ou supervisent le système	Confiance excessive dans le score du modèle, sans remise en question

Catégorie de biais	Origine	Exemple Axodia
 Ce que recommande le NIST Le NIST AI RMF souligne que le biais ne se limite pas à un défaut technique corrigible par un ajustement statistique : il naît souvent de décisions humaines antérieures, reproduites fidèlement par un modèle qui apprend ce qu'on lui montre — d'où l'importance d'examiner les données d'entraînement autant que le modèle lui-même.		
 Bon à savoir L'équité en intelligence artificielle ne se résume pas à traiter tout le monde de façon identique : elle suppose parfois de corriger explicitement un déséquilibre hérité de pratiques passées, ce qui implique des choix qui dépassent la seule technique et engagent la responsabilité de l'organisation.		

Ce que signifie une supervision humaine réelle

L'AI Act impose, pour les systèmes à haut risque, une supervision humaine effective — non une validation de façade où une personne se contente d'entériner systématiquement la sortie du modèle sans capacité réelle de la contester. Chez Axodia, Claire décide qu'aucune candidature ne pourra être écartée automatiquement sans qu'un recruteur humain ait consulté le dossier complet, y compris pour les profils que le modèle recommande d'écarter.

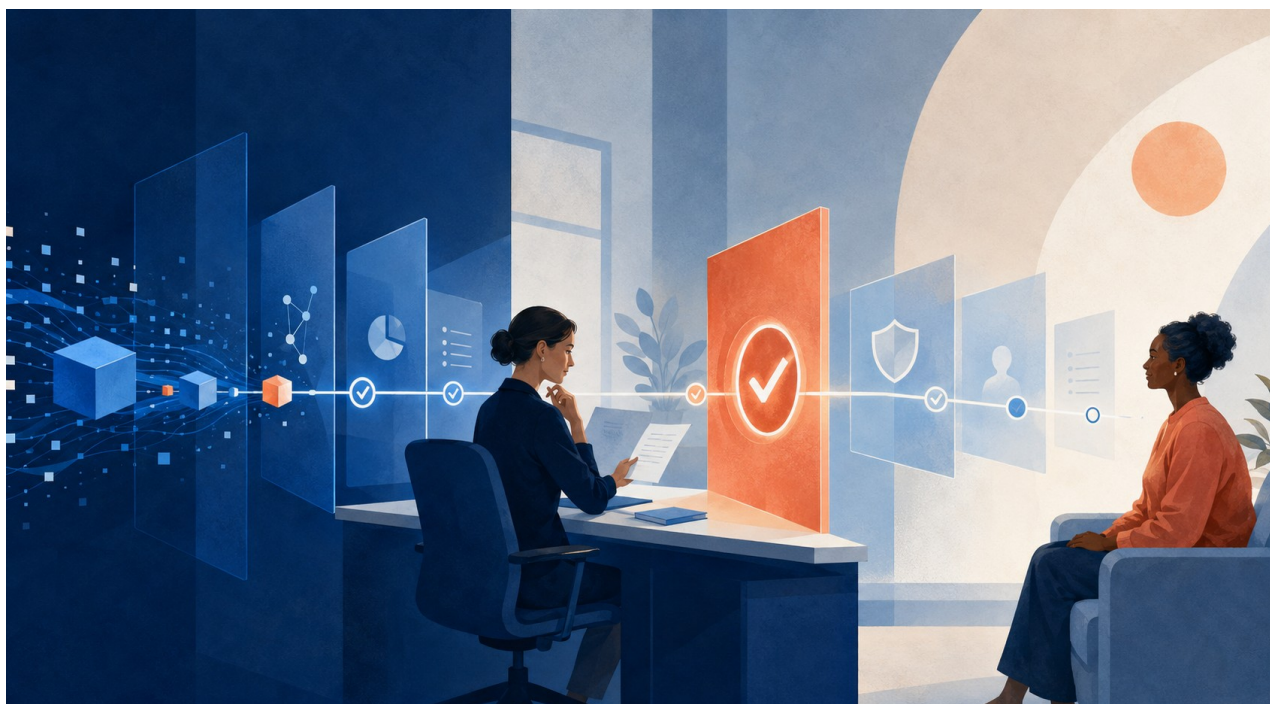


Figure 9 — La supervision humaine est un pouvoir réel d'examiner, contester et interrompre une décision automatisée.

Ce que dit l'AI Act

La supervision humaine, telle qu'exigée pour les systèmes à haut risque, suppose que la personne en charge dispose du temps, des informations et de l'autorité réelle pour ignorer ou corriger une recommandation du système — une simple case cochée sans examen ne satisfait pas cette exigence.

Risque fréquent

L'automatisation du biais : croire qu'un système « objectif » élimine par nature les préjugés humains, alors qu'il les reproduit fidèlement s'il a été entraîné sur des décisions historiques biaisées.

Bonnes pratiques

Auditer périodiquement les décisions du système par sous-groupe de population (durée d'interruption de carrière, origine de la candidature, etc.), pas seulement sur la performance globale.

Conseil d'expert

Impliquez systématiquement les équipes métier — ici les recruteurs de Claire — dans l'audit d'équité : elles perçoivent souvent des irrégularités qu'aucune métrique statistique ne signale spontanément.

Quiz — Testez votre compréhension

Question 1 — À quelle catégorie appartient un biais hérité de décisions humaines historiques reproduites par le modèle ?

- a) Biais cognitif humain uniquement.
- b) Biais systémique.
- c) Il n'existe pas de biais de ce type.

Question 2 — Que signifie une supervision humaine réelle selon l'AI Act ?

- a) Une case cochée automatiquement par un logiciel.
- b) Une personne disposant du temps, des informations et de l'autorité réelle pour contester une recommandation du système.
- c) Un rapport mensuel envoyé à la direction.

Question 3 — Pourquoi un système jugé « objectif » peut-il pourtant être biaisé ?

- a) Parce que les systèmes d'IA ne peuvent jamais être objectifs.

- b) Parce qu'il peut reproduire fidèlement des préjugés présents dans les données ou décisions historiques utilisées pour l'entraîner.
- c) Parce que la loi l'exige.

Corrigé du quiz

1-b · 2-b · 3-b

Ce qu'il faut retenir

- Trois catégories de biais coexistent : systémique, computationnel/statistique, cognitif humain — souvent combinées dans un même système.
- Un modèle « objectif » peut reproduire fidèlement des préjugés hérités de décisions humaines passées.
- La supervision humaine exigée par l'AI Act suppose une capacité réelle de contestation, pas une validation de façade.
- Auditer par sous-groupe de population révèle des écarts invisibles dans une performance globale agrégée.

Pour aller plus loin

- NIST AI 100-1, section consacrée à l'équité et aux biais préjudiciables.
- Recommandation sur l'éthique de l'intelligence artificielle, UNESCO, 2021, chapitre sur l'équité et la non-discrimination.

La Partie IV se referme : Axodia sait désormais mesurer, protéger techniquement et auditer l'équité de ses systèmes. Reste l'étape la plus attendue par Nadia depuis le premier jour — transformer tout ce travail en conformité formelle à l'AI Act. C'est l'objet de la Partie V, à partir du chapitre 13.

Chapitre 13 — Systèmes à haut risque : les 10 obligations

Objectifs pédagogiques

- Connaître les dix obligations imposées par l'AI Act aux systèmes à haut risque.
- Savoir constituer les preuves attendues pour chacune.
- Utiliser la checklist AI Act comme outil de pilotage, pas seulement de contrôle final.

La scène : la checklist de Nadia

Nadia réunit Sophie et Marc autour d'un tableau à dix lignes : les dix obligations que l'AI Act impose aux deux systèmes à haut risque d'Axodia, le scoring crédit et la présélection des candidatures.

Nadia — « *Ce n'est pas une liste à cocher une fois pour toutes. Chaque ligne doit rester vraie à tout moment, y compris dans six mois si le modèle est mis à jour.* »

Les dix obligations, en clair

Obligation	Ce qu'elle exige concrètement
1. Système de gestion des risques	Un processus documenté et actualisé (chapitre 9), pas une analyse ponctuelle
2. Gouvernance des données	Données d'entraînement pertinentes, représentatives et documentées
3. Documentation technique	Description complète du système, de ses finalités et de ses limites
4. Tenue de registres (journalisation)	Conservation des journaux permettant de retracer le fonctionnement du système
5. Transparence envers les utilisateurs	Instructions d'utilisation claires, y compris pour les opérateurs internes
6. Supervision humaine effective	Capacité réelle d'un humain à contester ou corriger une sortie (chapitre 12)

Obligation	Ce qu'elle exige concrètement
7. Exactitude, robustesse, cybersécurité	Performances mesurées (chapitre 10) et résistance aux usages malveillants
8. Système de gestion de la qualité	Processus organisationnels garantissant la conformité dans la durée
9. Évaluation de conformité	Vérification, interne ou par un tiers, avant et pendant l'exploitation
10. Enregistrement dans la base de données de l'UE	Déclaration du système dans le registre européen des systèmes à haut risque

Ce que dit l'AI Act

Ces dix obligations s'appliquent au fournisseur du système à haut risque, mais plusieurs incombent également au déployeur — l'entité qui exploite le système au quotidien, ici Axodia pour le scoring crédit conçu en partie avec un prestataire externe. Bien identifier qui, du fournisseur ou du déployeur, porte chaque obligation évite les angles morts (approfondi au chapitre 14).

Conseil d'expert

Utilisez la checklist AI Act comme outil de pilotage vivant du comité IA, revu à chaque réunion, plutôt que comme document produit une seule fois pour un audit ponctuel.

Risque fréquent

Traiter la documentation technique comme un exercice rétroactif, rédigé après coup pour satisfaire un contrôle. Une documentation construite au fil du projet coûte moins cher et reflète mieux la réalité qu'une reconstitution a posteriori.

Bonnes pratiques

Désigner, pour chacune des dix obligations, un responsable nommé au sein du comité IA — la matrice RACI du chapitre 5 s'étend naturellement à cette checklist.

Quiz — Testez votre compréhension

Question 1 — Laquelle de ces obligations concerne la capacité d'un humain à contester une sortie du système ?

- a) La tenue de registres.
- b) La supervision humaine effective.
- c) L'enregistrement dans la base de données de l'UE.

Question 2 — Pourquoi la documentation technique ne doit-elle pas être rédigée après coup ?

- a) Parce que la loi l'interdit littéralement.
- b) Parce qu'une documentation construite au fil du projet est moins coûteuse et plus fidèle à la réalité.
- c) Parce qu'elle doit être rédigée uniquement par un avocat.

Corrigé du quiz

1-b · 2-b

Ce qu'il faut retenir

- Les dix obligations des systèmes à haut risque couvrent la gestion des risques, les données, la documentation, la traçabilité, la transparence, la supervision humaine, la robustesse, la qualité, l'évaluation de conformité et l'enregistrement européen.
- Certaines obligations incombent au fournisseur, d'autres au déployeur — la distinction est cruciale et se clarifie au chapitre 14.
- La checklist AI Act doit être un outil vivant, revu régulièrement, non un document figé produit pour un contrôle ponctuel.

Pour aller plus loin

- Règlement (UE) 2024/1689 (AI Act), chapitre consacré aux exigences applicables aux systèmes d'IA à haut risque.

Reste une question que Nadia n'a pas encore tranchée : quand un système à haut risque s'appuie sur un modèle de fondation conçu par un tiers, qui porte réellement chacune de ces dix obligations ? C'est l'objet du chapitre 14.

Chapitre 14 — GPAI et modèles de fondation : qui est responsable ?

Objectifs pédagogiques

- Comprendre le régime spécifique de l'AI Act applicable aux modèles d'IA à usage général (GPAI).
- Identifier les quatre maillons de la chaîne de responsabilité, du fournisseur au déployeur.
- Situer la responsabilité d'Axodia dans l'usage d'un modèle de fondation externe.

La scène : « ce n'est pas nous qui avons entraîné le modèle »

Marc soulève un point que personne n'avait formalisé : Aria repose sur un grand modèle de langage fourni par un éditeur tiers, qu'Axodia a ensuite personnalisé (fine-tuné) sur ses propres données de service client.

Marc — « Si le modèle de base a un défaut, c'est la responsabilité de l'éditeur, pas la nôtre, non ? »

Nadia — « Pas aussi simplement. L'AI Act construit une chaîne de responsabilité : chacun répond de ce qu'il ajoute, pas seulement de ce qu'il a créé de zéro. »

La chaîne de responsabilité GPAI

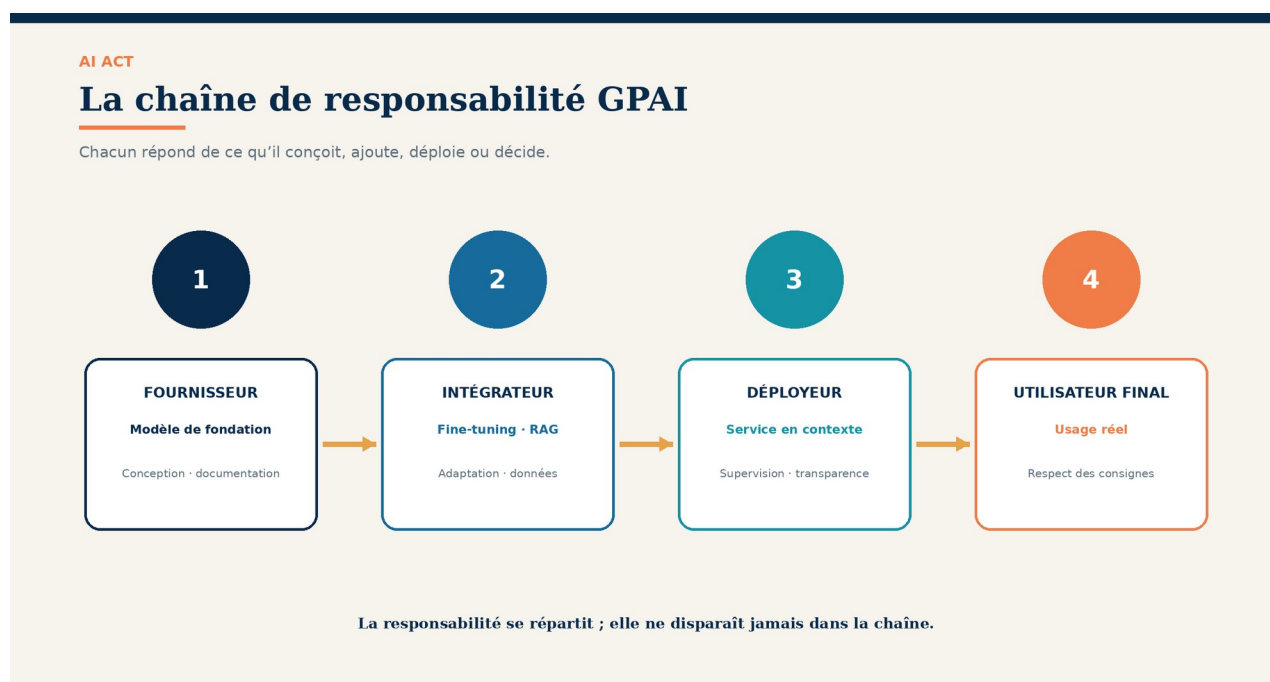


Figure 10 — La chaîne GPAI : chacun répond de ce qu'il conçoit, ajoute, déploie ou décide.

Maillon	Rôle	Ce qu'il porte comme responsabilité
Fournisseur du modèle de fondation	Conçoit et entraîne le modèle d'usage général	Documentation du modèle, transparence sur les données d'entraînement, évaluation des risques systémiques le cas échéant
Intégrateur / fine-tuneur (Axodia, DSI)	Personnalise le modèle pour un usage précis	Documentation des adaptations apportées, tests spécifiques à l'usage retenu
Déploieur (Axodia Care)	Exploite le système auprès des utilisateurs finaux	Supervision humaine, transparence envers les clients, surveillance continue
Utilisateur final (client d'Axodia)	Interagit avec le système	Aucune obligation légale, mais un droit à être informé et protégé

Maillon	Rôle	Ce qu'il porte comme responsabilité
 Ce que dit l'AI Act		
Le règlement distingue les modèles GPAI standards des modèles dits « à risque systémique », ces derniers identifiés notamment par un seuil de puissance de calcul mobilisée pour l'entraînement (de l'ordre de 10^{25} opérations en virgule flottante). Les modèles à risque systémique sont soumis à des obligations renforcées de leur fournisseur, indépendamment de l'usage qu'en font ensuite leurs clients.		
 Conseil d'expert		
Documentez systématiquement, dans le registre des systèmes d'IA, le fournisseur du modèle sous-jacent et la nature exacte de la personnalisation apportée (fine-tuning, prompt engineering, garde-fous ajoutés) — cette traçabilité conditionne la répartition réelle des responsabilités.		
 Risque fréquent		
Croire que l'usage d'un modèle tiers exonère intégralement l'organisation qui le personnalise et le déploie. Le fine-tuning et le déploiement créent des obligations propres, distinctes de celles du fournisseur d'origine.		

Quiz — Testez votre compréhension

Question 1 — Qui, dans la chaîne GPAI, porte l'obligation de supervision humaine effective auprès des clients ?

- a) Le fournisseur du modèle de fondation uniquement.
- b) Le déployeur, qui exploite le système auprès des utilisateurs finaux.
- c) L'utilisateur final.

Question 2 — Qu'est-ce qui distingue un modèle GPAI « à risque systémique » d'un modèle GPAI standard ?

- a) Son prix d'achat.
- b) Un seuil de puissance de calcul mobilisée pour l'entraînement, entraînant des obligations renforcées.
- c) Sa date de sortie sur le marché.

Corrigé du quiz

1-b · 2-b

Ce qu'il faut retenir

- L'usage d'un modèle GPAI tiers n'exonère pas l'organisation qui le personnalise et le déploie de ses propres obligations.
- Quatre maillons se répartissent la responsabilité : fournisseur, intégrateur/fine-tuneur, déployeur, utilisateur final.
- Les modèles à risque systémique, identifiés notamment par un seuil de puissance de calcul, sont soumis à des obligations renforcées de leur fournisseur.
- Documenter la nature exacte de la personnalisation apportée conditionne la clarté de la répartition des responsabilités.

Pour aller plus loin

- Règlement (UE) 2024/1689 (AI Act), dispositions relatives aux modèles d'IA à usage général.

La responsabilité est désormais claire, maillon par maillon. Mais Axodia, en tant qu'entreprise de taille intermédiaire, dispose-t-elle des mêmes obligations qu'un grand groupe ? C'est la question du chapitre 15.

Chapitre 15 — PME, bacs à sable et dispositions allégées

Objectifs pédagogiques

- Connaître les dispositifs prévus par l'AI Act pour les PME et ETI.
- Comprendre le fonctionnement des bacs à sable réglementaires (regulatory sandboxes).
- Identifier les allègements documentaires réellement applicables à Axodia.

La scène : « on n'a pas les moyens d'un grand groupe »

Thomas s'inquiète du coût de mise en conformité rapporté à la taille d'Axodia, entreprise de taille intermédiaire d'environ 3 200 salariés.

Thomas — « On n'a pas les équipes juridiques d'un grand groupe du CAC 40. Est-ce que la loi prévoit quelque chose pour nous ? »

Nadia — « En partie, oui. Ce n'est pas une exemption, mais un allègement bien réel sur la forme, pas sur le fond. »

Ce que prévoit l'AI Act pour les plus petites structures

Le règlement européen prévoit plusieurs dispositifs destinés à ne pas faire peser sur les PME et ETI une charge disproportionnée, sans jamais réduire le niveau de protection attendu pour les personnes concernées.

Dispositif	Ce qu'il apporte
Bacs à sable réglementaires (sandboxes)	Un cadre de test supervisé par une autorité, permettant d'expérimenter un système avant une mise en conformité complète
Documentation technique simplifiée	Des formats allégés, proportionnés à la taille de l'organisation et au risque réel du système
Évaluation de conformité à coût réduit	Un accès facilité aux organismes d'évaluation pour les structures de taille modeste

Dispositif	Ce qu'il apporte
Accompagnement et information prioritaires	Un accès privilégié aux autorités nationales compétentes pour les questions d'application
 Bon à savoir Un bac à sable réglementaire n'est pas une zone de non-droit : les principes fondamentaux de l'AI Act continuent de s'appliquer, mais sous la supervision d'une autorité qui accompagne l'organisation dans sa mise en conformité progressive, plutôt que de sanctionner immédiatement un écart.	
 Conseil d'expert Ne présumez jamais qu'un allègement documentaire dispense d'une obligation de fond, comme la supervision humaine ou la gestion des risques. Les allègements portent sur la forme et la proportionnalité, jamais sur le niveau de protection attendu.	
 Risque fréquent Invoquer sa taille pour justifier une non-conformité de fond. Les dispositifs PME allègent la charge administrative ; ils ne créent aucune exception aux obligations essentielles des systèmes à haut risque.	

Quiz — Testez votre compréhension

Question 1 — Qu'est-ce qu'un bac à sable réglementaire au sens de l'AI Act ?

- a) Une zone où aucune règle ne s'applique.
- b) Un cadre de test supervisé par une autorité, permettant d'expérimenter avant une mise en conformité complète.
- c) Un espace de formation destiné aux étudiants.

Question 2 — Les allègements prévus pour les PME portent-ils sur les obligations de fond (comme la supervision humaine) ?

- a) Oui, elles en sont totalement exemptées.
- b) Non, les allègements concernent la forme et la proportionnalité, pas le niveau de protection attendu.
- c) Cela dépend uniquement du secteur d'activité.

Corrigé du quiz

1-b · 2-b

Ce qu'il faut retenir

- L'AI Act prévoit des bacs à sable réglementaires, une documentation simplifiée et un accompagnement facilité pour les PME et ETI.
- Ces dispositifs allègent la charge administrative, jamais les obligations de fond attendues pour la protection des personnes.
- Un bac à sable reste supervisé par une autorité : ce n'est pas une exemption réglementaire.

Pour aller plus loin

- Règlement (UE) 2024/1689 (AI Act), dispositions relatives aux mesures de soutien à l'innovation et aux PME.

Thomas est rassuré sans être dispensé d'agir. Reste à mesurer concrètement ce qu'il en coûterait de ne pas agir — c'est l'objet du chapitre 16.

Chapitre 16 — Sanctions, contentieux et cas vécus

Objectifs pédagogiques

- Connaître les barèmes de sanctions prévus par l'AI Act.
- Comprendre la jurisprudence naissante autour des agents conversationnels.
- Tirer les enseignements du cas Aria à la lumière d'une année de travail de gouvernance.

La scène : le bilan que personne n'espérait devoir faire

Nadia présente au comité un tableau qu'elle espérait ne jamais avoir à commenter avec autant de précision : les montants réels que l'incident du prologue aurait pu coûter à Axodia si le comité de gouvernance n'avait pas été créé à temps.

Les barèmes de sanctions de l'AI Act

Type de manquement	Sanction maximale
Usage d'une pratique interdite (risque inacceptable)	35 millions d'euros ou 7 % du chiffre d'affaires mondial annuel
Non-conformité aux obligations des systèmes à haut risque	15 millions d'euros ou 3 % du chiffre d'affaires mondial annuel
Information incorrecte, incomplète ou trompeuse transmise aux autorités	7,5 millions d'euros ou 1,5 % du chiffre d'affaires mondial annuel



Ce que dit l'AI Act

Ces montants représentent des plafonds, calculés selon le plus élevé des deux montants (somme fixe ou pourcentage du chiffre d'affaires mondial), et s'appliquent en tenant compte de la gravité, de la durée et du caractère intentionnel ou non du manquement.

Le précédent qui a inspiré le prologue

Le cas d'Aria n'est pas une fiction gratuite : il s'inspire directement d'un précédent réel largement documenté, celui d'une compagnie aérienne dont le chatbot avait promis à tort un remboursement à un client, avant qu'un tribunal ne juge que l'entreprise devait honorer cet engagement, au motif qu'elle demeure responsable des déclarations de l'outil qu'elle met en avant face à ses clients. Ce précédent, antérieur à l'entrée en application intégrale de l'AI Act, illustre qu'une organisation peut être tenue pour responsable des actes de son IA indépendamment même du texte du règlement, sur le fondement du droit commun de la responsabilité contractuelle.



Pour aller plus loin

Ce précédent souligne un point que ce livre répète depuis le prologue : la gouvernance IA n'est pas seulement une question de conformité à un texte récent, mais une question de responsabilité générale de l'entreprise envers ceux qu'elle sert.

Quiz — Testez votre compréhension

Question 1 — Quel est le plafond de sanction pour l'usage d'une pratique interdite au sens de l'AI Act ?

- a) 7,5 millions d'euros ou 1,5 % du chiffre d'affaires mondial.
- b) 35 millions d'euros ou 7 % du chiffre d'affaires mondial.
- c) Il n'existe aucune sanction financière, seulement un avertissement.

Question 2 — Le précédent du chatbot évoqué dans ce chapitre repose sur quel fondement juridique ?

- a) L'AI Act exclusivement.
- b) Le droit commun de la responsabilité contractuelle, une entreprise répondant des engagements pris par son propre outil.
- c) Aucun fondement juridique reconnu.

Corrigé du quiz

1-b · 2-b

Ce qu'il faut retenir

- Les sanctions de l'AI Act atteignent jusqu'à 35 millions d'euros ou 7 % du chiffre d'affaires mondial pour les manquements les plus graves.

- Une entreprise peut être tenue responsable des déclarations de son IA sur le fondement du droit commun, indépendamment même de l'AI Act.
- La gouvernance IA protège autant contre le risque réglementaire que contre le risque juridique et réputationnel général.

Pour aller plus loin

- Règlement (UE) 2024/1689 (AI Act), dispositions relatives aux sanctions.

La Partie V se referme sur ce constat sobre : la conformité n'est pas une option. Reste à transformer tout ce travail en habitude durable — c'est l'objet de la Partie VI, qui s'ouvre au chapitre 17.

Chapitre 17 — Traiter et suivre les risques

Objectifs pédagogiques

- Appliquer la fonction MANAGE du NIST AI RMF pour traiter les risques cartographiés au chapitre 9.
- Choisir entre éviter, réduire, transférer ou accepter un risque.
- Construire un tableau de bord de gouvernance IA avec des indicateurs KPI et KRI.

La scène : du diagnostic à la décision

Le comité IA revient sur les cinq risques identifiés lors de l'atelier du chapitre 9. Il ne s'agit plus de les décrire, mais de décider, pour chacun, d'un traitement précis et d'un responsable nommé.

Sophie — « Pour chaque risque, quatre options : l'éviter en renonçant à la fonctionnalité, le réduire par un contrôle supplémentaire, le transférer — par exemple contractuellement à notre fournisseur — ou l'accepter en connaissance de cause, avec l'aval de Thomas. »

La fonction MANAGE du NIST AI RMF

Après avoir cartographié (MAP) et mesuré (MEASURE), la fonction MANAGE consiste à prioriser les risques selon leur criticité, à mettre en œuvre les réponses retenues, à surveiller leur évolution dans le temps et à communiquer régulièrement sur l'état du dispositif — à la direction, mais aussi, le cas échéant, aux personnes concernées.

Risque (Aria)	Traitement retenu	Responsable
Hallucination commerciale	Réduire — garde-fou de sortie NLI (chapitre 11)	Karim
Fuite d'information confidentielle	Réduire — garde-fou de contexte restreignant les documents mobilisables	Karim
Usage détourné	Accepter avec surveillance renforcée	Sophie
Indisponibilité prolongée	Transférer — clause de continuité avec le fournisseur	Marc

Risque (Aria)	Traitement retenu	Responsable
Dérive progressive non détectée	Réduire — tableau de bord et revue mensuelle	Léa
 Ce que recommande le NIST La fonction MANAGE insiste sur la communication continue des risques traités et résiduels — vers la direction, mais aussi vers les utilisateurs finaux quand cela est pertinent. Un risque accepté doit rester visible, pas simplement archivé.		
 Bon à savoir Un KPI (indicateur de performance) mesure si le système atteint ses objectifs ; un KRI (indicateur de risque) alerte en amont d'une dégradation potentielle. Les deux sont complémentaires : un KPI qui reste bon peut masquer un KRI déjà orienté à la baisse.		
 Conseil d'expert Limitez le tableau de bord de gouvernance IA à une dizaine d'indicateurs réellement suivis plutôt qu'à une longue liste jamais consultée. Un tableau de bord surchargé finit toujours par être ignoré.		
 Risque fréquent Accepter un risque une fois, en réunion, puis l'oublier. Un risque accepté doit être revu périodiquement : le contexte qui justifiait cette acceptation peut évoluer.		

Quiz — Testez votre compréhension

Question 1 — Quelles sont les quatre options de traitement d'un risque ?

- a) Ignorer, minimiser, externaliser, publier.
- b) Éviter, réduire, transférer, accepter.
- c) Documenter, certifier, publier, contester.

Question 2 — Quelle est la différence entre un KPI et un KRI ?

- a) Il n'y en a aucune.
- b) Le KPI mesure la performance, le KRI alerte en amont d'une dégradation potentielle.
- c) Le KRI concerne uniquement les finances.

Corrigé du quiz

1-b · 2-b

Ce qu'il faut retenir

- La fonction MANAGE du NIST AI RMF priorise, traite, surveille et communique les risques identifiés.
- Quatre options de traitement existent : éviter, réduire, transférer, accepter — chacune avec un responsable nommé.
- KPI et KRI se complètent : la performance actuelle ne garantit pas l'absence de dégradation à venir.
- Un risque accepté doit rester visible et être revu périodiquement, pas archivé définitivement.

Pour aller plus loin

- NIST AI 100-1, section consacrée à la fonction MANAGE.

Le dispositif tourne désormais en continu. Reste à savoir comment Axodia prouvera, face à un regard extérieur, que tout ce travail est réel — c'est l'objet du chapitre 18.

Chapitre 18 — Auditer son IA : méthode et posture

Objectifs pédagogiques

- Distinguer audit interne et audit externe (organismes notifiés).
- Structurer un plan d'audit IA : périmètre, référentiel, échantillon, calendrier.
- Adopter la bonne posture face à un auditeur.

La scène : l'arrivée de Yannick

Dix mois après le prologue, Yannick Bourdin, auditeur externe mandaté pour évaluer la maturité de la gouvernance IA d'Axodia en vue d'un appel d'offres important, se présente au siège. Sophie, nerveuse malgré des mois de préparation, l'accueille avec le registre, les comptes rendus de comité et le tableau de bord sous le bras.

Yannick — « Je ne suis pas là pour vous piéger. Je suis là pour vérifier que ce que vous dites faire correspond à ce que vous faites réellement — montrez-moi les preuves, pas les intentions. »

Construire un plan d'audit

Un audit — interne ou externe — se structure autour de quatre éléments : le périmètre exact couvert (quels systèmes, quelles branches), le référentiel utilisé comme grille de lecture (ISO 42001, AI Act, ou les deux), un échantillon représentatif de preuves à examiner, et un calendrier réaliste.

Élément du plan d'audit	Choix retenu pour Axodia
Périmètre	Aria (Axodia Care) et scoring crédit (Axodia Assurances)
Référentiel	ISO/IEC 42001 (clauses 4 à 10) et checklist AI Act (chapitre 13)
Échantillon	Six mois de comptes rendus de comité, le registre des incidents, un échantillon de décisions de scoring
Calendrier	Deux semaines de préparation, trois jours d'entretiens et de vérification documentaire

Élément du plan d'audit	Choix retenu pour Axodia
 Conseil d'expert	Préparez une salle de preuves — physique ou numérique — organisée exactement selon les clauses ISO 42001 ou les obligations de l'AI Act, plutôt que de chercher les documents en temps réel devant l'auditeur. La fluidité de cette présentation est, à elle seule, un signal de maturité.
 Bon à savoir	Les questions les plus fréquentes d'un auditeur portent rarement sur la technique pure : elles portent sur la traçabilité des décisions (« qui a validé ceci, et sur quelle base ? ») et sur la réalité du fonctionnement du comité de gouvernance.
 Risque fréquent	Adopter une posture défensive ou minimiser un écart constaté. Un auditeur valorise davantage une organisation qui reconnaît un écart et présente son plan de correction qu'une organisation qui nie l'évidence.
 Bonnes pratiques	Documenter, y compris les décisions imparfaites ou les risques encore en cours de traitement — un dossier trop lisse éveille souvent plus de suspicion qu'un dossier honnête montrant un travail en cours.

Quiz — Testez votre compréhension

Question 1 — Quels sont les quatre éléments structurants d'un plan d'audit ?

- a) Budget, équipe, logiciel, présentation.
- b) Périmètre, référentiel, échantillon, calendrier.
- c) Direction, marketing, juridique, technique.

Question 2 — Quelle posture privilégier face à un écart constaté par l'auditeur ?

- a) Le nier fermement.
- b) Le reconnaître et présenter le plan de correction associé.
- c) Changer de sujet et attendre la fin de l'entretien.

Corrigé du quiz

1-b · 2-b

**Pour aller plus loin**

Fiche mémo — Les questions d'un auditeur : Qui a validé ce système avant sa mise en production ? Comment le risque a-t-il été évalué et par qui ? Quelles preuves de supervision humaine effective disposez-vous ? Comment un incident serait-il détecté et traité ? Quand ce document a-t-il été mis à jour pour la dernière fois ?

Ce qu'il faut retenir

- Un plan d'audit se structure autour du périmètre, du référentiel, de l'échantillon et du calendrier.
- Un auditeur valorise la traçabilité des décisions et la réalité du fonctionnement du comité, plus que la seule technique.
- Reconnaître un écart et présenter un plan de correction inspire davantage confiance qu'un dossier artificiellement lisse.

Pour aller plus loin

- ISO/IEC 42001:2023, clause 9 (évaluation des performances) et exigences relatives à l'audit interne.

L'audit de Yannick se conclut sans surprise majeure — un vrai contraste avec le chaos du prologue. Reste à transformer les quelques écarts relevés en apprentissage durable, plutôt qu'en simple case cochée. C'est l'objet du chapitre 19.

Chapitre 19 — Incidents, crise et amélioration continue

Objectifs pédagogiques

- Construire un registre des incidents IA exploitable.
- Structurer une boucle d'amélioration continue conforme à la clause 10 d'ISO 42001.
- Comparer la gestion d'un incident mineur post-gouvernance à celle du prologue.

La scène : un incident mineur, une réponse mature

Onze mois après le prologue, Aria commet une nouvelle erreur — mineure cette fois : elle recommande à un client une option de service qui n'existe plus depuis un mois, sans conséquence financière. Le contraste avec l'incident initial est total.

Le garde-fou de sortie détecte l'incohérence avec la documentation à jour et bloque la réponse avant son envoi. Karim reçoit une alerte automatique, consigne l'incident dans le registre dédié en quinze minutes, et Léa identifie la cause racine dans l'après-midi : une mise à jour de l'offre commerciale n'avait pas été répercutée dans les documents mobilisables par Aria.



Figure 11 — La maturité ne supprime pas l'incident : elle accélère sa détection et transforme l'erreur en apprentissage.

✓ Bonnes pratiques

La différence entre le prologue et cet épisode ne tient pas à l'absence d'erreur — les systèmes d'IA en produiront toujours — mais à la vitesse et à la qualité de détection, de traitement et d'apprentissage.

Le registre des incidents IA

Champ	Renseignement pour cet incident
Description	Recommandation d'une option de service obsolète
Gravité	Mineure — bloquée avant transmission au client
Cause racine	Documentation commerciale non synchronisée avec la base de connaissances d'Aria
Mesure corrective	Automatiser la synchronisation entre le catalogue d'offres et la base documentaire d'Aria

Champ	Renseignement pour cet incident
Responsable	Léa, avec suivi par Karim

La boucle d'amélioration continue

ISO/IEC 42001, dans sa clause 10, attend de l'organisation qu'elle traite les non-conformités identifiées et qu'elle améliore en continu son système de management — pas seulement qu'elle corrige l'incident ponctuel, mais qu'elle en tire une action structurelle. Ici, la synchronisation automatisée du catalogue prévient toute une classe d'incidents futurs, pas seulement celui qui vient de se produire.

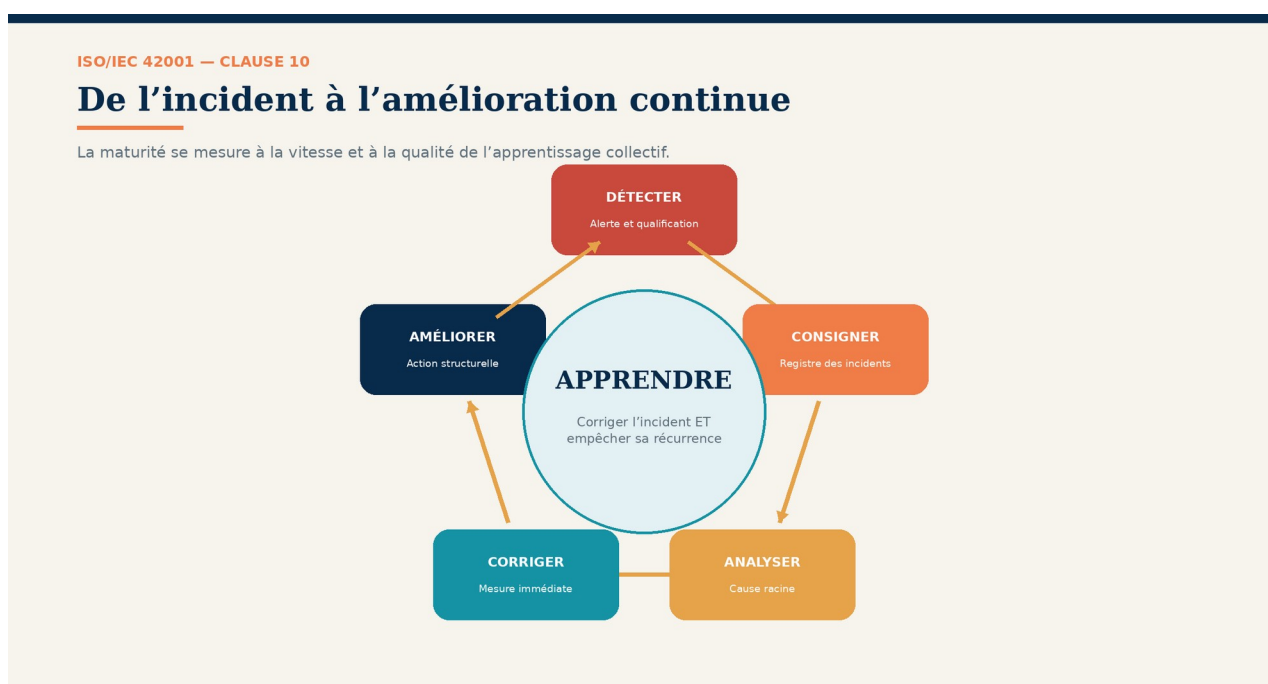


Figure 12 — La boucle d'amélioration continue : détecter, consigner, analyser, corriger et améliorer.

Ce que dit ISO 42001

La clause 10 distingue le traitement immédiat d'une non-conformité (corriger l'incident) de l'action corrective (empêcher sa récurrence) — les deux sont exigées, la seconde étant souvent négligée par excès de hâte à refermer le dossier.

Conseil d'expert

Consacrez, lors de chaque revue du comité IA, un temps dédié non pas aux incidents individuels mais aux tendances qu'ils révèlent collectivement — c'est souvent là que se cache l'amélioration structurelle la plus rentable.

** Risque fréquent**

Refermer un incident après la seule correction ponctuelle, sans identifier ni traiter sa cause racine — le même incident, ou une variante, se reproduit alors presque systématiquement.

Quiz — Testez votre compréhension

Question 1 — Quelle est la différence entre corriger un incident et mener une action corrective ?

- a) Il n'y en a aucune.
- b) Corriger traite l'incident ponctuel ; l'action corrective en empêche la récurrence.
- c) L'action corrective concerne uniquement les incidents graves.

Question 2 — Qu'est-ce qui distingue la gestion de l'incident du chapitre 19 de celle du prologue ?

- a) Rien, les deux incidents ont eu les mêmes conséquences.
- b) La vitesse et la qualité de détection, de traitement et d'apprentissage, grâce à la gouvernance mise en place.
- c) L'incident du chapitre 19 n'a impliqué aucun humain.

Corrigé du quiz

1-b · 2-b

Ce qu'il faut retenir

- Un registre des incidents IA exploitable documente description, gravité, cause racine, mesure corrective et responsable.
- La clause 10 d'ISO 42001 exige à la fois la correction ponctuelle et l'action corrective structurée.
- La maturité d'une gouvernance IA se juge à la vitesse et à la qualité de sa réponse aux incidents, pas à leur absence totale, illusoire.
- Analyser les tendances collectives des incidents révèle souvent plus d'enseignements que l'analyse isolée de chaque cas.

Pour aller plus loin

- ISO/IEC 42001:2023, clause 10 (amélioration continue et traitement des non-conformités).

Il reste un dernier chantier à Sophie avant la fin de cette première année : faire vivre cette culture bien au-delà du comité restreint qui l'a construite. C'est l'objet du chapitre 20, le dernier avant l'épilogue.

Chapitre 20 — Former, embarquer et essayer la culture IA responsable

Objectifs pédagogiques

- Concevoir un plan de formation à la gouvernance IA adapté à des publics différents.
- Distinguer sensibilisation générale et formation approfondie selon les rôles.
- Mesurer l'appropriation réelle de la culture IA responsable dans l'organisation.

La scène : la charte ne suffit plus

Claire présente au comité les résultats d'une enquête interne : la charte IA du chapitre 6 est connue de 90 % des collaborateurs, mais seuls 40 % savent citer un exemple concret de bonne pratique. Sophie et Claire décident qu'un document, aussi bien écrit soit-il, ne suffit jamais seul à changer une culture.

Un plan de formation à plusieurs niveaux

Public	Contenu de formation	Format
Tous les collaborateurs	Charte IA, usages autorisés/interdits, réflexe de signalement	Module court à l'onboarding, rappel annuel
Porteurs de projets IA	Registre, classification du risque, checklist AI Act	Atelier pratique d'une demi-journée
Comité de gouvernance	Évolutions réglementaires, retours d'audit, tendances sectorielles	Session trimestrielle avec intervenant externe
Direction	Enjeux stratégiques, risques réputationnels, retour sur investissement de la confiance	Brief annuel condensé

Public	Contenu de formation	Format
	 Bon à savoir Les principes de l'OCDE et la Recommandation de l'UNESCO insistent l'un comme l'autre sur le renforcement des capacités humaines comme condition de toute IA digne de confiance à long terme — un système bien gouverné sur le papier reste fragile si les personnes qui l'entourent n'en comprennent pas les enjeux.	
	 Conseil d'expert Mesurez l'appropriation par des indicateurs comportementaux (nombre de signalements spontanés, participation aux ateliers) plutôt que par le seul taux de lecture d'un document — la lecture ne garantit jamais la compréhension.	
	 Risque fréquent Considérer la formation comme un projet ponctuel de lancement plutôt que comme un cycle récurrent, aligné sur l'évolution des systèmes d'IA et des référentiels eux-mêmes.	
	 Bonnes pratiques Valoriser publiquement, en comité comme en communication interne, les signalements spontanés d'un risque par un collaborateur — le geste qui a manqué le plus cruellement lors de l'incident du prologue.	

Quiz — Testez votre compréhension

Question 1 — Pourquoi une charte bien écrite ne suffit-elle pas à elle seule à changer une culture ?

- a) Parce que les chartes sont interdites par la loi.
- b) Parce que la lecture d'un document ne garantit pas sa compréhension ni son appropriation réelle.
- c) Parce que les collaborateurs ne savent pas lire.

Question 2 — Quel type d'indicateur mesure le mieux l'appropriation réelle de la culture IA responsable ?

- a) Le taux de lecture du document.
- b) Des indicateurs comportementaux, comme les signalements spontanés ou la participation aux ateliers.

- c) Le nombre de pages de la charte.

Corrigé du quiz

1-b · 2-b

Ce qu'il faut retenir

- Un plan de formation efficace distingue les publics : tous les collaborateurs, porteurs de projets, comité de gouvernance, direction.
- L'appropriation réelle se mesure par des indicateurs comportementaux, pas par le seul taux de lecture d'un document.
- La formation à la gouvernance IA est un cycle récurrent, aligné sur l'évolution des systèmes et des référentiels, jamais un projet ponctuel.
- Valoriser les signalements spontanés ancre durablement le réflexe qui a manqué au début de cette histoire.

Pour aller plus loin

- Principes de l'OCDE sur l'intelligence artificielle, section sur le renforcement des capacités et la littératie numérique.
- Recommandation sur l'éthique de l'intelligence artificielle, UNESCO, 2021, chapitre sur l'éducation et la sensibilisation.

La Partie VI se referme sur cette conviction : une gouvernance IA ne tient que si elle est portée collectivement, bien au-delà du comité qui l'a fondée. Il reste à Sophie et à toute l'équipe une dernière étape avant de tourner la page de cette première année — celle de l'épilogue.

Épilogue — Un an plus tard

Un an, presque jour pour jour, après la réunion de crise du prologue, Sophie relit le rapport final de Yannick Bourdin. Sur les dix obligations examinées pour les deux systèmes à haut risque, sur les sept piliers de confiance passés en revue, sur la totalité du cycle ISO 42001 audité, aucun écart majeur n'est relevé — seulement trois observations mineures, déjà inscrites dans le plan de traitement des risques avant même la fin de l'audit.

Le rapport atterrit à un moment stratégique : Axodia est en compétition pour un contrat majeur avec un grand groupe industriel européen, dont l'appel d'offres inclut, pour la première fois, une clause explicite d'évaluation de la gouvernance IA du prestataire. Thomas convoque le comité une dernière fois avant la remise de l'offre.

Thomas — *« Il y a un an, je vous ai dit que je n'avais plus le choix. Aujourd'hui, je crois qu'on peut dire que la gouvernance IA n'a pas seulement évité un désastre — elle est devenue un avantage qu'aucun concurrent qui n'a pas fait ce chemin ne pourra présenter aussi vite. »*

Axodia remporte le contrat trois semaines plus tard. Le client, lors du débriefing, cite explicitement la clarté du registre des systèmes d'IA et la rigueur du plan de traitement des risques comme facteurs différenciants dans sa décision.

Ce que devient chacun

Marc, longtemps sceptique, dirige désormais lui-même la revue technique trimestrielle des garde-fous — il reconnaît, sans grande solennité mais sans détour, que la gouvernance a fini par accélérer certains projets plutôt que les ralentir, en évitant des reprises coûteuses après coup. Claire a vu son enquête de culture IA devenir un indicateur suivi chaque trimestre par la direction des ressources humaines du groupe. Karim a formalisé l'architecture de garde-fous d'Aria en un standard interne, repris depuis pour tout nouveau projet conversationnel. Nadia continue de veiller, désormais avec une checklist qui ne tient plus sur un tableau blanc mais dans un outil partagé par toute l'équipe. Léa, elle, a été nommée référente technique de la gouvernance IA — la trajectoire qu'elle n'imaginait pas un an plus tôt, quand elle surveillait seule un tableau de bord un mardi de mars.

« On ne gouverne pas ce qu'on ne comprend pas, et l'on ne comprend pas ce qu'on n'a jamais cartographié. » — Sophie Marchal — la même phrase, un an plus tard, affichée désormais dans la salle du comité

IA

Sophie referme le rapport de Yannick et rouvre, par réflexe, le tableau blanc qui a vu naître, un an plus tôt, un magma d'acronymes sans queue ni tête. Il est propre, à jour, structuré. Elle sait qu'il ne le restera jamais totalement : de nouveaux systèmes arriveront, de nouveaux référentiels évolueront, de nouveaux incidents surviendront — c'est la nature même d'une gouvernance vivante. Mais elle sait aussi, désormais, exactement par où recommencer à chaque fois. C'est peut-être cela, au fond, gouverner l'intelligence artificielle : non pas atteindre un état parfait et définitif, mais savoir, à chaque nouvelle question, où et comment chercher la réponse.

Boîte à outils complète

Les quinze modèles introduits au fil des chapitres, réunis ici pour un usage direct. Chaque outil rappelle son chapitre d'origine et les champs essentiels à renseigner.

1. Registre des systèmes d'IA — Chapitre 7

Nom du système · Finalité métier · Données traitées · Niveau de risque · Propriétaire métier · Statut · Fournisseur/tiers impliqué

2. Politique IA — Chapitre 6

Principes directeurs · Périmètre d'application · Gouvernance et rôles · Sanctions internes en cas de manquement · Date de revue

3. Charte IA — Chapitre 6

Usages autorisés · Usages interdits · Devoirs de vigilance · Canal de signalement · Engagement individuel signé

4. Analyse de risques IA — Chapitre 9

Scénario de risque · Probabilité · Impact · Criticité · Mesures de traitement envisagées

5. Cartographie des systèmes d'IA — Chapitre 7

Vue par branche métier · Systèmes associés · Niveau de criticité · Interdépendances

6. Matrice de criticité — Chapitre 9

Grille probabilité (1-5) x impact (1-5) · Seuils d'acceptabilité · Code couleur de priorisation

7. Fiche projet IA — Chapitre 7

Finalité · Données mobilisées · Parties prenantes · Jalons de conformité · Date de revue prévue

8. Checklist AI Act (haut risque) — Chapitre 13

Les dix obligations · Statut de chacune · Preuves associées · Responsable nommé

9. Plan d'audit IA — Chapitre 18

Périmètre · Référentiel · Échantillon de preuves · Calendrier · Auditeur(s) mandaté(s)

10. Matrice RACI gouvernance IA — Chapitre 5

Activité · Responsable · Accountable (un seul) · Consulted · Informed

11. Tableau de bord gouvernance IA — Chapitre 17

Indicateurs KPI · Indicateurs KRI · Statut des plans de traitement · Fréquence de revue

12. Registre des incidents IA — Chapitre 19

Description · Gravité · Cause racine · Mesure corrective · Responsable · Statut

13. Compte rendu de comité IA — Chapitre 5

Ordre du jour · Décisions prises · Actions et échéances · Participants · Prochaine réunion

14. Plan de traitement des risques — Chapitre 17

Risque · Option retenue (éviter/réduire/transférer/accepter) · Responsable · Échéance · Statut

15. Plan d'amélioration continue — Chapitre 19

Constat · Action corrective · Indicateur de succès · Date de revue · Clôture

Glossaire francophone de la gouvernance IA

AI Act — Règlement (UE) 2024/1689 établissant des règles harmonisées concernant l'intelligence artificielle dans l'Union européenne.

AIMS — Système de management de l'intelligence artificielle (AI Management System), au sens d'ISO/IEC 42001.

Biais algorithmique — Écart de traitement systématique et injustifié produit par un système d'IA entre des groupes de personnes.

Déployeur — Entité qui exploite un système d'IA auprès de ses utilisateurs finaux, au sens de l'AI Act.

Fournisseur — Entité qui conçoit et met sur le marché un système d'IA ou un modèle de fondation.

Garde-fou (Guardrail) — Mécanisme technique de vérification appliqué en entrée, en sortie ou sur le contexte d'un système d'IA générative.

Gouvernance de l'IA — Ensemble des règles, rôles, processus et outils par lesquels une organisation encadre la conception, le déploiement et l'usage de ses systèmes d'IA.

GPAI — Modèle d'intelligence artificielle à usage général (General-Purpose AI), soumis à un régime spécifique de l'AI Act.

Hallucination — Réponse plausible mais fausse produite avec assurance par un modèle de langage.

Haut risque — Catégorie de systèmes d'IA soumis, au sens de l'AI Act, à dix obligations renforcées en raison de leur impact potentiel sur les personnes.

ISO/IEC 22989 — Norme internationale de vocabulaire et de concepts de référence en intelligence artificielle.

ISO/IEC 23894 — Norme internationale de gestion du risque appliquée à l'intelligence artificielle.

ISO/IEC 42001 — Norme internationale certifiable de système de management de l'intelligence artificielle.

KPI / KRI — Indicateur de performance (Key Performance Indicator) et indicateur de risque (Key Risk Indicator).

NIST AI RMF — Cadre volontaire de gestion des risques liés à l'IA publié par le National Institute of Standards and Technology (États-Unis).

RACI — Méthode de clarification des rôles : Responsible, Accountable, Consulted, Informed.

Registre des systèmes d'IA — Inventaire structuré des systèmes d'IA conçus, acquis ou exploités par une organisation.

Shadow AI — Système d'IA utilisé par des équipes sans validation ni déclaration officielle.

Supervision humaine effective — Capacité réelle d'une personne à contester ou corriger la sortie d'un système d'IA, au-delà d'une validation de façade.

TEVV — Test, Évaluation, Vérification, Validation — les quatre activités de mesure de la fiabilité d'un système d'IA.

Trustworthy AI (IA digne de confiance) — Système d'IA dont les sept caractéristiques de confiance (fiabilité, sûreté, sécurité, redevabilité/transparence, explicabilité, respect de la vie privée, équité) sont connues, documentées et surveillées.

Bibliographie et sources

Textes réglementaires et normatifs

- Règlement (UE) 2024/1689 du Parlement européen et du Conseil établissant des règles harmonisées concernant l'intelligence artificielle (règlement sur l'intelligence artificielle), Journal officiel de l'Union européenne, 2024.
- ISO/IEC 42001:2023 — Technologies de l'information — Intelligence artificielle — Système de management, Organisation internationale de normalisation, 2023.
- ISO/IEC 23894:2023 — Technologies de l'information — Intelligence artificielle — Management du risque, Organisation internationale de normalisation, 2023.
- ISO/IEC 22989:2022 — Technologies de l'information — Intelligence artificielle — Concepts et terminologie, Organisation internationale de normalisation, 2022.
- NIST AI 100-1 — Artificial Intelligence Risk Management Framework (AI RMF 1.0), National Institute of Standards and Technology, janvier 2023.

Principes et recommandations internationales

- Recommandation sur l'éthique de l'intelligence artificielle, Organisation des Nations unies pour l'éducation, la science et la culture (UNESCO), adoptée en 2021.
- Principes de l'OCDE sur l'intelligence artificielle, Organisation de coopération et de développement économiques, adoptés en 2019, révisés en 2024.

Ressources pédagogiques ayant nourri la synthèse de cet ouvrage

- Guide de synthèse sur le règlement européen relatif à l'intelligence artificielle, document de vulgarisation fourni en préparation de cet ouvrage.
- Guide de synthèse sur les garde-fous techniques des grands modèles de langage (Guardrails), inspiré des travaux pédagogiques de DeepLearning.AI et de la bibliothèque GuardrailsAI, document fourni en préparation de cet ouvrage.

Note sur les cas cités

Le cas du chatbot promettant à tort un remboursement, évoqué au prologue et repris au chapitre 16, s'inspire d'un précédent réel largement documenté dans la presse spécialisée et les guides pédagogiques consacrés aux garde-fous de l'IA conversationnelle, concernant une compagnie aérienne dont un tribunal a jugé qu'elle devait honorer l'engagement erroné pris par son propre agent conversationnel.

Les autres cas évoqués (outil de tri des candidatures écarté pour biais de genre, systèmes d'aide à la décision judiciaire ou administrative) renvoient à des controverses publiques largement documentées dans la presse économique et technologique internationale entre 2018 et aujourd'hui, mobilisées ici à titre d'illustration générale plutôt que comme étude de cas juridique détaillée.

Conformément à la note méthodologique du document de cadrage éditorial, aucun passage des textes ISO, du règlement européen ou du cadre NIST n'a été reproduit mot pour mot dans cet ouvrage : chaque référentiel a été synthétisé, reformulé et mis en contexte narratif, avec attribution systématique de son origine.

Annexe — Le règlement européen sur l'intelligence artificielle (UE 2024/1689) : synthèse structurée

Cette annexe propose une synthèse structurée et fidèle du règlement (UE) 2024/1689 du Parlement européen et du Conseil du 13 juin 2024 établissant des règles harmonisées concernant l'intelligence artificielle, publié au Journal officiel de l'Union européenne (série L, 2024/1689) le 12 juillet 2024. Il ne s'agit pas d'une reproduction du texte légal — dont la version intégrale et opposable reste, en toute circonstance, celle publiée au Journal officiel, consultable à l'adresse eur-lex.europa.eu/eli/reg/2024/1689/oj — mais d'une carte de lecture destinée à situer rapidement une obligation dans l'architecture du texte avant, le cas échéant, d'aller consulter l'article correspondant dans sa formulation officielle.

Architecture générale du texte

Le règlement comprend 113 articles et 13 annexes, répartis en treize titres :

Titre	Contenu
I	Dispositions générales — objet, champ d'application, définitions, maîtrise de l'IA (art. 1 à 4).
II	Pratiques interdites en matière d'IA (art. 5).
III	Systèmes d'IA à haut risque — classification, exigences, obligations des opérateurs, organismes notifiés, évaluation de la conformité (art. 6 à 49).
IV	Obligations de transparence pour certains systèmes d'IA (art. 50).
V	Modèles d'IA à usage général (art. 51 à 56).
VI	Mesures de soutien à l'innovation — bacs à sable réglementaires, essais en conditions réelles, mesures pour les PME (art. 57 à 63).
VII	Gouvernance au niveau de l'Union et des États membres (art. 64 à 70).

Titre	Contenu
VIII	Base de données de l'UE, surveillance après commercialisation, partage d'informations, notification d'incidents graves (art. 71 à 73).
IX	Surveillance du marché, procédures en cas de systèmes présentant un risque, mesures correctives (art. 74 à 84).
X	Codes de conduite et lignes directrices (art. 85 à 86).
XI	Délégation de pouvoir et comité (art. 87 à 98).
XII	Sanctions (art. 99 à 101).
XIII	Dispositions finales — modifications d'actes existants, entrée en vigueur et application (art. 102 à 113).

Définitions clés (article 3)

L'article 3 pose 68 définitions. Les plus structurantes pour la lecture du reste du règlement :

Système d'IA — Système fondé sur une machine, conçu pour fonctionner avec un niveau d'autonomie variable et pouvant faire preuve d'adaptabilité après son déploiement, qui, pour des objectifs explicites ou implicites, déduit à partir des entrées qu'il reçoit la manière de générer des sorties telles que des prédictions, du contenu, des recommandations ou des décisions pouvant influencer des environnements physiques ou virtuels.

Fournisseur — Personne physique ou morale qui développe un système d'IA ou un modèle d'IA à usage général, ou le fait développer, et le met sur le marché ou le met en service sous son propre nom ou sa propre marque, à titre onéreux ou gratuit.

Déployeur — Personne physique ou morale qui utilise, sous sa propre autorité, un système d'IA — sauf dans le cadre d'une activité personnelle à caractère non professionnel.

Mise sur le marché — Première mise à disposition d'un système d'IA sur le marché de l'Union.

Mise en service — Fourniture d'un système d'IA à un premier utilisateur pour une utilisation directe, ou pour un usage propre, conformément à sa destination.

Risque — Combinaison de la probabilité d'un préjudice et de la gravité de ce préjudice.

Modèle d'IA à usage général (GPAI) — Modèle entraîné sur de grands volumes de données, présentant une généralité significative et capable d'exécuter, avec compétence, un large éventail de tâches distinctes, quelle que soit la manière dont il est mis sur le marché, et pouvant être intégré dans divers systèmes ou applications en aval.

Risque systémique — Risque propre aux capacités à fort impact des modèles d'IA à usage général, ayant une incidence significative sur le marché de l'Union en raison de leur portée, ou en raison d'effets négatifs réels ou raisonnablement prévisibles sur la santé publique, la sécurité, les droits fondamentaux ou la société dans son ensemble, susceptible de se propager à grande échelle tout au long de la chaîne de valeur.

Autorité de surveillance du marché — Autorité nationale chargée de mener les activités et de prendre les mesures prévues par le règlement (UE) 2019/1020 (surveillance du marché des produits).

Article 5 — Les pratiques interdites

Huit catégories de pratiques d'IA sont interdites sans exception (sous réserve d'exceptions strictement encadrées pour la dernière) car jugées incompatibles avec les valeurs de l'Union :

1. Les techniques subliminales, manipulatrices ou trompeuses altérant substantiellement le comportement d'une personne d'une manière causant un préjudice important.
2. L'exploitation des vulnérabilités liées à l'âge, au handicap ou à une situation sociale ou économique spécifique, dans le même but.
3. La notation sociale (social scoring) de personnes physiques par des acteurs publics ou privés, entraînant un traitement défavorable disproportionné ou hors contexte.
4. L'évaluation ou la prédiction du risque qu'une personne commette une infraction pénale sur la seule base d'un profilage ou de traits de personnalité.
5. La constitution ou l'extension de bases de données de reconnaissance faciale par moissonnage non ciblé d'images sur Internet ou de la vidéosurveillance.
6. La reconnaissance des émotions sur le lieu de travail et dans les établissements d'enseignement, sauf raisons médicales ou de sécurité.
7. La catégorisation biométrique visant à déduire l'origine raciale ou ethnique, les opinions politiques, l'affiliation syndicale, les convictions religieuses ou philosophiques, la vie sexuelle ou l'orientation sexuelle d'une personne.
8. L'identification biométrique à distance « en temps réel » dans des espaces accessibles au public à des fins répressives — interdite par principe, sauf exceptions limitativement énumérées (recherche de vic

times, menace terroriste imminente, poursuite d'infractions graves) et soumise à autorisation judiciaire ou administrative préalable.

Les systèmes d'IA à haut risque

L'article 6 fixe deux voies de classification : un système d'IA est à haut risque s'il constitue un composant de sécurité d'un produit déjà soumis à évaluation de conformité par un tiers au titre de la législation d'harmonisation de l'Union (annexe I — machines, jouets, dispositifs médicaux, aviation, automobile, etc.), ou s'il relève de l'un des huit domaines d'usage énumérés à l'annexe III :

Biométrie — Identification biométrique à distance non interdite, catégorisation biométrique, reconnaissance des émotions dans les cas non couverts par l'interdiction de l'article 5.

Infrastructures critiques — Systèmes utilisés comme composants de sécurité dans la gestion et l'exploitation de l'énergie, de l'eau, du gaz, du chauffage, de l'infrastructure numérique critique et du trafic routier.

Éducation et formation professionnelle — Détermination de l'accès ou de l'admission, évaluation des résultats d'apprentissage, orientation du parcours éducatif, surveillance et détection de comportement interdit pendant les examens.

Emploi, gestion des travailleurs et accès à l'emploi indépendant — Recrutement (diffusion d'offres ciblées, analyse et filtrage des candidatures, évaluation des candidats), décisions relatives aux conditions de travail, promotion et rupture des relations contractuelles, répartition des tâches, suivi et évaluation de la performance et du comportement.

Accès aux services essentiels publics et privés — Évaluation de l'éligibilité aux prestations sociales, scoring de solvabilité et de crédit, tarification en matière d'assurance-vie et d'assurance-maladie, tri des appels d'urgence et répartition des services de secours (police, pompiers, aide médicale).

Activités répressives — Évaluation du risque qu'une personne soit victime d'infractions ou du risque de récidive, polygraphes et outils similaires, évaluation de la fiabilité des éléments de preuve, profilage de personnes physiques dans le cadre d'enquêtes.

Migration, asile et gestion des frontières — Polygraphes, évaluation du risque migratoire ou sécuritaire posé par une personne, examen des demandes d'asile, de visa ou de titre de séjour, détection, reconnaissance ou identification de personnes dans ce contexte.

Administration de la justice et processus démocratiques — Aide à la recherche et à l'interprétation des faits et du droit, aide à l'application du droit à un ensemble concret de faits, systèmes destinés à influencer le résultat d'une élection ou d'un référendum ou le comportement de vote des personnes.

L'article 6, paragraphe 3, prévoit toutefois une exception : un système relevant de l'annexe III n'est pas considéré comme à haut risque s'il ne présente pas de risque significatif d'atteinte à la santé, à la sécurité ou aux droits fondamentaux, notamment parce qu'il n'influence pas matériellement le résultat de la prise de décision. C'est le cas, par exemple, d'un système destiné à accomplir une tâche procédurale étroite, à améliorer le résultat d'une activité humaine déjà réalisée, à détecter des écarts par rapport à un schéma de décision antérieur sans s'y substituer, ou à exécuter une tâche préparatoire à une évaluation. Le fournisseur qui invoque cette exception doit documenter son évaluation et l'enregistrer avant la mise sur le marché ; l'autorité compétente peut la contester a posteriori.

Les six exigences cumulatives (articles 8 à 15)

Art. 9 — Système de gestion des risques — Processus itératif et continu, mené tout au long du cycle de vie du système, qui identifie et analyse les risques connus et raisonnablement prévisibles, estime et évalue les risques résiduels, adopte des mesures de gestion appropriées et prévoit des tests avant la mise sur le marché.

Art. 10 — Gouvernance des données — Les ensembles de données d'entraînement, de validation et de test doivent être pertinents, suffisamment représentatifs, dans la mesure du possible exempts d'erreurs et complets au regard de la destination du système, avec un examen des biais susceptibles d'affecter la santé, la sécurité ou les droits fondamentaux, ou de conduire à une discrimination interdite.

Art. 11 — Documentation technique — Établie avant la mise sur le marché et tenue à jour, elle doit démontrer la conformité du système et fournir aux autorités les informations nécessaires pour évaluer cette conformité (contenu minimal détaillé à l'annexe IV).

Art. 12 — Tenue de registres (journalisation) — Le système doit permettre l'enregistrement automatique d'événements (« logs ») pendant toute la durée de son fonctionnement, à un niveau assurant la traçabilité adaptée à sa destination et permettant d'identifier des situations pouvant présenter un risque ou entraîner une modification substantielle.

Art. 13 — Transparence et information des déployeurs — Le système doit être accompagné d'une notice d'utilisation claire précisant son identité, ses caractéristiques, ses capacités et limites de performance, les circonstances pouvant entraîner un risque, et les mesures de contrôle humain prévues.

Art. 14 — Contrôle humain — Conçu pour pouvoir être effectivement supervisé par des personnes physiques pendant la période d'utilisation, au moyen de mesures intégrées au système ou identifiées par le fournisseur pour mise en œuvre par le déployeur — incluant la possibilité de comprendre les capacités du système, de rester vigilant à l'« automation bias », d'interpréter correctement sa sortie et de pouvoir décider de ne pas l'utiliser ou d'interrompre son fonctionnement (« bouton d'arrêt »).

Art. 15 — Exactitude, robustesse et cybersécurité — Niveau approprié tout au long du cycle de vie, avec résilience face aux erreurs, aux défaillances, aux incohérences et aux tentatives de manipulation malveillante des données d'entrée (empoisonnement de données, exemples contradictoires, extraction de modèle).

Les obligations réparties par rôle (articles 16 à 27)

Fournisseur (art. 16) — Assure la conformité aux exigences, met en place un système de gestion de la qualité, établit la documentation technique, conserve les journaux, réalise la procédure d'évaluation de conformité applicable, appose le marquage CE, enregistre le système dans la base de données de l'UE et met en œuvre un système de surveillance après commercialisation.

Mandataire (art. 22) — Établi dans l'Union lorsque le fournisseur est situé dans un pays tiers ; vérifie l'existence de la documentation et de la déclaration de conformité, tient à disposition des autorités les coordonnées du fournisseur et coopère avec elles.

Importateur (art. 23) — Vérifie avant mise sur le marché que le système porte le marquage CE, que la documentation technique existe et que la procédure d'évaluation de conformité a été réalisée ; indique son identité sur le produit ou son emballage.

Distributeur (art. 24) — Vérifie la présence du marquage CE, de la déclaration de conformité et de la notice d'utilisation avant de mettre le système à disposition sur le marché ; s'assure des conditions de stockage et de transport adéquates.

Déploieur (art. 26) — Utilise le système conformément à sa notice, assigne un contrôle humain à des personnes compétentes et disposant de l'autorité nécessaire, surveille le fonctionnement du système, informe les travailleurs concernés, et — pour certains déploieurs publics ou systèmes touchant des services essentiels — réalise une analyse d'impact sur les droits fondamentaux (art. 27) avant la mise en service.

Article 50 — Transparence pour certains systèmes

Indépendamment de leur niveau de risque, certains systèmes sont soumis à une obligation de transparence spécifique :

- Signaler, au plus tard lors de la première interaction, qu'une personne physique communique avec un système d'IA plutôt qu'avec un être humain (agents conversationnels), sauf si cela est évident du point de vue d'une personne raisonnablement informée.

- Marquer les contenus synthétiques (audio, image, vidéo ou texte) générés ou manipulés par IA de façon lisible par machine et détectable comme générés ou manipulés artificiellement — obligation à la charge du fournisseur du système.
- Informer les personnes physiques exposées à un système de reconnaissance des émotions ou de catégorisation biométrique de son fonctionnement.
- Étiqueter comme tel tout contenu (« deepfake ») représentant des personnes, objets, lieux, entités ou événements réalistes et faussement perçus comme authentiques.
- Divulguer qu'un texte publié dans le but d'informer le public sur des sujets d'intérêt public a été généré ou manipulé par IA, sauf s'il a fait l'objet d'un examen humain ou d'un contrôle éditorial et qu'une personne physique ou morale assume la responsabilité éditoriale du contenu.

Titre V — Les modèles d'IA à usage général (GPAI)

Les fournisseurs de modèles à usage général (GPAI — General-Purpose AI), quel que soit le système dans lequel ils sont ensuite intégrés, doivent respecter un socle d'obligations : tenir une documentation technique à jour et la fournir sur demande au Bureau de l'IA, transmettre aux fournisseurs en aval les informations nécessaires pour qu'ils comprennent les capacités et limites du modèle et puissent s'y conformer, mettre en place une politique de respect du droit d'auteur et de la législation sur la propriété intellectuelle, et publier un résumé suffisamment détaillé, selon un modèle fourni par le Bureau de l'IA, des données utilisées pour l'entraînement.

Les modèles jugés à « risque systémique » sont soumis à des obligations renforcées. Le règlement présume ce risque systémique lorsque la puissance de calcul cumulée utilisée pour l'entraînement, mesurée en opérations à virgule flottante, dépasse un seuil de 10^{25} FLOPs — la Commission pouvant ajuster ce seuil par acte délégué à mesure que l'état de l'art évolue, ou désigner un modèle comme systémique sur la base d'autres critères (nombre d'utilisateurs actifs, modalités, autonomie). Ces fournisseurs doivent en outre : évaluer le modèle selon des protocoles et outils normalisés, y compris par des tests contradictoires (« red teaming ») ; évaluer et atténuer les risques systémiques éventuels au niveau de l'Union ; assurer le suivi, la documentation et la notification sans délai injustifié des incidents graves et des mesures correctives au Bureau de l'IA ; garantir un niveau adéquat de protection en matière de cybersécurité pour le modèle et son infrastructure physique. Des codes de bonnes pratiques (« codes of practice »), élaborés avec l'industrie, la société civile et le monde académique, servent de référentiel de conformité présumée en attendant l'adoption de normes harmonisées.

Titre VI — Mesures de soutien à l'innovation

Pour ne pas freiner l'innovation, notamment des PME et jeunes pousses, le règlement impose à chaque État membre la mise en place d'au moins un bac à sable réglementaire de l'IA (« regulatory sandbox »), gratuit ou à coût raisonnable. Ce dispositif permet de développer, entraîner, valider et tester un système d'IA innovant sous la supervision directe et l'accompagnement des autorités compétentes, pendant une durée limitée et avant sa mise sur le marché, avec un plan convenu conjointement. Les autorités de contrôle ne peuvent pas infliger d'amende pour des infractions commises de bonne foi dans le cadre du bac à sable, dans les limites du plan approuvé. Le règlement encourage également les tests en conditions réelles en dehors des bacs à sable, sous réserve d'un consentement éclairé des participants et de garanties strictes, ainsi qu'un accès prioritaire simplifié pour les PME et jeunes pousses.

Gouvernance

Le règlement instaure une gouvernance à deux niveaux. Au niveau de l'Union : le Bureau de l'IA (AI Office), rattaché à la Commission, supervise notamment les modèles à usage général, coordonne l'application cohérente du règlement, peut mener des évaluations des modèles GPAI et demander des mesures correctives ; le Comité européen de l'intelligence artificielle réunit un représentant de chaque État membre pour assurer la cohérence d'application et conseiller la Commission ; un forum consultatif représentant les parties prenantes (industrie, PME, société civile, monde académique) et un groupe scientifique d'experts indépendants apportent respectivement l'expertise sectorielle et technique, ce dernier pouvant notamment alerter le Bureau de l'IA sur des risques systémiques émergents. Au niveau national : chaque État membre désigne une autorité notifiante (habilitant et contrôlant les organismes d'évaluation de la conformité) et une ou plusieurs autorités de surveillance du marché, chargées du contrôle effectif sur le terrain, disposant de pouvoirs d'accès à la documentation, au code source dans certaines conditions, et de retrait du marché.

Sanctions

Manquement	Amende maximale
Violation des pratiques interdites (art. 5)	35 000 000 € ou 7 % du chiffre d'affaires mondial annuel, le montant le plus élevé étant retenu

Manquement	Amende maximale
Non-respect des obligations relatives aux systèmes à haut risque ou aux modèles GPAI	15 000 000 € ou 3 % du chiffre d'affaires mondial annuel
Communication d'informations inexactes, incomplètes ou trompeuses aux autorités	7 500 000 € ou 1 % du chiffre d'affaires mondial annuel

Pour les PME et jeunes pousses, c'est le plus bas des deux montants (fixe ou pourcentage) qui s'applique, et non le plus élevé, afin de proportionner la sanction à la taille réelle de l'entreprise.

Calendrier d'entrée en application

Le règlement est entré en vigueur le 1er août 2024 (vingt jours après sa publication), mais son application est échelonnée sur trois ans pour laisser aux organisations le temps de s'adapter :

Échéance	Dispositions applicables
2 février 2025 (+ 6 mois)	Dispositions générales et pratiques interdites (titres I et II) ; obligations de maîtrise de l'IA.
2 août 2025 (+ 12 mois)	Gouvernance, obligations relatives aux modèles d'IA à usage général, régime des sanctions.
2 août 2026 (+ 24 mois)	Application générale du règlement, notamment les systèmes à haut risque de l'annexe III et les obligations de transparence de l'article 50.
2 août 2027 (+ 36 mois)	Systèmes à haut risque constituant des composants de sécurité de produits déjà réglementés (annexe I — machines, jouets, dispositifs médicaux, etc.).

Les treize annexes du règlement

Annexe	Objet
I	Liste de la législation d'harmonisation de l'Union pertinente pour la classification des systèmes à haut risque en tant que composants de sécurité de produits.

Annexe	Objet
II	Liste des infractions pénales pouvant justifier une identification biométrique à distance à des fins répressives.
III	Liste des systèmes d'IA à haut risque par domaine d'usage (les huit catégories détaillées plus haut).
IV	Contenu requis de la documentation technique des systèmes à haut risque.
V	Modèle de déclaration UE de conformité.
VI	Procédure d'évaluation de la conformité fondée sur le contrôle interne.
VII	Procédure d'évaluation de la conformité fondée sur un système de gestion de la qualité et l'examen de la documentation technique (avec organisme notifié).
VIII	Informations à enregistrer dans la base de données de l'UE sur les systèmes à haut risque.
IX	Évaluation de la conformité applicable aux systèmes déjà soumis à d'autres procédures sectorielles (annexe I, section A).
X	Actes législatifs de l'Union relatifs aux systèmes informatiques à grande échelle dans l'espace de liberté, de sécurité et de justice.
XI	Documentation technique exigée des fournisseurs de modèles d'IA à usage général.
XII	Informations de transparence à fournir par les fournisseurs de modèles GPAI aux fournisseurs en aval.
XIII	Critères de désignation des modèles d'IA à usage général présentant un risque systémique.

À retenir

Cette synthèse couvre l'intégralité de l'architecture du règlement, mais reste un résumé de travail. Pour toute décision de conformité, se référer systématiquement au texte publié au Journal officiel de l'Union européenne (règlement (UE) 2024/1689, JO L, 12.7.2024) — la seule version faisant foi.